Contents

Volume 01 — Introduction & Foundations **1**
Lecture T01: Course Welcome 1
Lecture T48: Introduction — Part 01 2
Lecture T03: Introduction — Part 02 4
Lecture T04: Introduction — Part 03 6
Lecture T05: Foundations — Part 01 7
Lecture T06: Foundations — Part 02 9
Lecture T07: Foundations — Part 03 10

Volume 01 — Introduction & Foundations

Cyber Security and Privacy · NPTEL 106106248 · Prof. Saji K. Mathew **notes-3** — concept exam notes (definitions & what things do). Breadth over lab depth.

Lecture T01: Course Welcome

Learning focus

- State why the course treats the cyber world as having a bright side and a dark side.
- Explain why cybersecurity is a management and governance issue, not a technology issue alone.
- Name the two kinds of cybersecurity planning this course will teach: contingency planning and risk-management planning.
- Trace the path from cybersecurity into information privacy, including why data, regulation, and stakeholders matter.

Key terms

Term	Meaning in this lecture
Dark side / dark world	The growing set of attacks, disruptions, and damages that travel with digital adoption
Digital assets	The technology and data on which a business or organization may wholly depend
GRC	Governance, risk, and compliance — the managerial frame for cybersecurity
Twofold role of technology	Technology can be attacked or destroyed; technology is also a source of protection
Contingency planning	Planning that assumes incidents (including ransomware) can happen, then restore and recover
Residual risk	The quantitative or qualitative leftover risk after valuing assets, threats, and probabilities
Risk-management planning	Preventive planning of management action per asset; not an assumption that harm has already occurred

Term	Meaning in this lecture
DPDP	Digital Personal Data Protection Act — India's then-pending privacy law
GDPR	European data-protection regulation, named as a global counterpart to DPDP

Frameworks / formulas

- **GRC triad (managerial):** governance + risk + compliance.
- **Two-track planning:** contingency (reactive recovery after incidents) versus risk management (preventive residual-risk action).
- **Course arc:** awareness → GRC/planning/standards → protection technologies (including cryptography and a guest practitioner) → information privacy (fundamentals, stakeholders, GDPR/DPDP, managerial–economic–strategy view).

Distinctions

- Technology's usefulness (ease, efficiency, effectiveness) is not the whole story; **adoption and dark-world challenges grow together**.
- This is **not** a technology-only course. Cybersecurity is also administration: GRC.
- Contingency planning **assumes something can already have gone wrong**; risk-management planning **does not** assume an incident has happened — it is preventive.
- Privacy is not a side topic bolted on at the end: **data is often what is at risk**, and cybersecurity technology is also a tool for protecting information privacy.

Exam lines

- Course thesis: digital technology eases work **and** creates a dark side that can collapse a digitally dependent organization.
- Audience: practicing managers and cybersecurity professionals; anyone who uses or is responsible for technology.
- Managerial core: GRC; planning of two kinds (contingency / residual-risk); standards.
- Technology: both target and protection; later, cryptography plus an industry guest.
- Privacy track: data value → fundamentals of privacy → DPDP, GDPR, Supreme Court right to privacy → stakeholders and strategy.

Lecture T48: Introduction — Part 01

Learning focus

- Give working meanings of **cybersecurity** and **privacy**, and say why their intersection matters.
- Explain why a manager, not only an IT person, should treat cybersecurity as a live concern.

- Distinguish **phishing**, **social engineering**, and **spear phishing** using the instructor's own mailbox examples.
- Contrast **ransomware** with **denial of service**, and say why healthcare data (AIIMS, HIPAA) is treated as especially sensitive.

Key terms

Term	Meaning in this lecture
Data / vulnerability / unauthorized access	The three student keywords the instructor keeps for "cybersecurity"
Privacy (working sense)	Me and my data; I choose what to disclose; distinct from a system-level security layer
Phishing	Fraudulent mail/message; everyday junk asking for bank or personal details
Social engineering	Collecting background on who is who so a fake mail is believable
Spear phishing	Specific, social-engineering-based phishing with a background study; higher response chance
Ransomware	Attacker encrypts / takes control of a machine and demands money for the key
Denial of service	Named only as **different** from ransomware; a DoS case is promised later
POS	Point of sale — checkout/payment machines in retail; if they stop, automated shops stop
HIPAA	US healthcare-data regulation, cited to explain why health records are treated as super sensitive

Frameworks / formulas

- **Check-the-sender / check-the-URL hygiene:** suspicious professional mail → inspect sender domain; sign-in SMS → inspect the real website address, not the lookalike page.
- **Bright side / dark side of digital:** more digitization, more reported attacks; cybersecurity is the dark-side concern.
- **Pay-versus-refuse ransomware:** per-hour business loss often dwarfs ransom (Kaseya pattern); refusal is illustrated only where systems were already obsolete (Chennai Corporation).

Distinctions

- Cybersecurity and privacy are **two terms in the title**; their **intersection** is part of the course, not a merge of the two words.
- A mail that does **not** ask for passwords can still be spear phishing; **tone and domain** can be the giveaway.
- Everyday phishing is obvious; **spear phishing** is dangerous because it impersonates someone inside your circle after reconnaissance.

- **DoS ≠ ransomware.** Ransomware is control + encryption + payment to release.
- Healthcare data is not "just another database": embarrassment, organizational harm, and dedicated law (HIPAA) explain why AIIMS was a national story.
- Paying ransom is common for **critical operations**; Chennai Corporation is taught as an **exception**, not the default.

Exam lines

- Managers should care because attacks already arrive as official-looking mail, fake bank pages, POS shutdowns, and hospital-server takeovers.
- Keep: data, vulnerability, unauthorized access; privacy as control over disclosure; intersection of the two.
- Spear phishing = phishing + social engineering + target-specific background.
- Ransomware lock-and-key analogy; Kaseya $70M; Chennai refusal on Windows 8.
- AIIMS + HIPAA: health data is super sensitive.
- EY 91% / CEO priority: this is not a niche IT problem.

Lecture T03: Introduction — Part 02

Learning focus

- Explain how internet-connected cars, IoT sensors, and drones move cyber risk from "lost data" to **halted systems and harm to people**.
- State the instructor's basic principle: **any device connected to the internet is not safe**.
- List the **units** cybersecurity affects: individuals, organizations, society, and government — including government's dual role.
- Articulate technology's **triple role**: source of threat, asset to protect, and defense weapon.

Key terms

Term	Meaning in this lecture
Smart connected devices / IoT	Devices with processing that connect to the internet and transmit data, not only PCs
"Any internet-connected device is not safe"	The basic principle stated for IoT / connected systems
Manufacturing 4.0	New generation of digital / smart manufacturing — taught as the bright side of the same sensors
Information security vs cybersecurity	Older focus on data in IS; cybersecurity is the more recent, wider term

Term	Meaning in this lecture
Scope widening	From information → infrastructure → people; damage to people is real
Units	Individuals, organizations, society, government — all have cyber challenges
Government's dual concern	Protect own systems/data **and** regulate for citizen welfare
Privacy as close cousin	Privacy / data protection interrelated with cybersecurity
Triple role of technology	Threat source, asset, defense weapon

Frameworks / formulas

- **Cars analogy:** do not ban the useful technology; **increase safety** (same logic as not abandoning digital tools).
- **Trade of privileges:** refusing WhatsApp / TV / social media can reduce exposure, but you **lose** digital privileges; most people will not take that path.
- **Triple-role test:** whenever "technology" is mentioned in a cybersecurity sentence, name whether it is the **attack tool**, the **asset**, or the **control**.

Distinctions

- Losing data on a computer is **not** the ceiling of harm; connected cars, refineries, and drones show **halted operations and harm to people**.
- Analog wired sensors were hard to manipulate remotely; **digital + internet** is what opens unauthorized access.
- Cybersecurity is **not** just a new name for information security; **people and infrastructure** are in scope.
- A hacked **IT company** (Twitter, TCS) is taught as **embarrassment and public explanation**, including the outsourcing excuse — not as proof that "tech firms cannot be hacked."
- "Cybersecurity technologies" **does not automatically mean defensive products**.
- Government is both a **potential victim** (Aadhaar-scale data) and a **regulator**; privacy will be discussed with a claim of party-neutrality.

Exam lines

- Connected cars + ICAT: cybersecurity testing because lives can be destroyed, not only data lost.
- Saudi refinery 16 Sep 2019, 4 a.m., drones; Citibank/ERP as "if IT stops, the organization stops."
- IoT principle: internet-connected ⇒ not safe; false temperature can wreck process control.
- Drones also kill (Soleimani); people are now in the security perimeter.
- Units: individual / organization / society / government; government = own systems + regulation.

- Technology = threat + asset + defense; DoS scripts and firewalls are both "technology."

Lecture T04: Introduction — Part 03

Learning focus

- Define **security** as a state (and a psychological sense) of being safe, then scale it from the individual to the organization.
- Distinguish **information security** from the wider **cybersecurity**, including the ITU 2008 definition and the spelling conventions.
- State the **CIA** triangle as the three elements cybersecurity/information security seeks to ensure, and quote the Whitman and Mattord definition of information security.
- Explain why this course is **management and governance first**, with technology in a threefold role, and preview GRC, two kinds of planning, Target/Sony, and privacy regulation.

Key terms

Term	Meaning in this lecture
Security (general)	A state of being safe / feeling secure; also psychological / emotional
Information security	Protect information as an asset (data, databases, systems that use/store/transmit it)
Cybersecurity	Information security **plus** individuals (and the networked world's users and systems); ITU 2008 is all-inclusive
Cybernetics	Greek origin: steersman / control; source of the prefix "cyber"
CIA triangle	Confidentiality, integrity, availability of information
False positive / false negative	Wrongly admitting someone without right, or wrongly denying someone with right (gate analogy)
Zero trust	"Trust none" — reduce dependence on human credibility
Contingency vs risk planning	Reactive restoration after failure vs preventive treatment of what can go wrong
Passive vs active defense	Walls / protection vs going beyond, including "shooting" / offending attackers (legal issues flagged)

Frameworks / formulas

- **Spelling rule:** any of the three written forms, **one convention per document**.
- **Whitman & Mattord (2018):** protection of information **and its critical elements**, including systems and hardware that **use, store, and transmit** that information.
- **ITU (2008):** long list (tools, policies, concepts, safeguards, guidelines, risk-management approaches, actions, training, best practices, assurance, technologies) — taught as **breadth**, not as a definition to memorize word-for-word.

- **Course stack:** foundations / CIA → Target (and Sony as twin shock) → GRC/ISO → contingency + risk → policy → crypto & defense (guest) → privacy regulation (NA, EU, India).

Distinctions

- Feeling secure is real, but organizational security is about **authorized vs unauthorized** entry and **verification**, including gate errors.
- **Information security ⊂ cybersecurity.** Adding "cyber" is not a synonym swap; **people** (cyber crime, drones, safety) enter the scope.
- US vs European **spelling** is a consistency issue, not a meaning issue.
- This course studies **what encryption does**, not **how the algorithms work**.
- Firewalls/IDS are **an** element; without **administration, standards, and national regulation**, investment incentives collapse.
- Contingency planning is **firefighting after failure**; risk management is **preventive** and does **not** assume the incident has already happened.
- Active defense is **not** a casual suggestion — **legal sides** matter.

Exam lines

- Security = state of safety (and a feeling); orgs protect physical + informational assets; gates implement authorized access with possible false +/−.
- Cyber from cybernetics (control / steersman) → internet-connected world.
- Cybersecurity = IS + individuals; ITU 2008 is deliberately all-inclusive.
- CIA is the purpose of information security management; Whitman–Mattord 2018 is the textbook definition.
- Managerial course: GRC, two planning types, policy, Target/Sony cases, guest on protection tech, then privacy law (GDPR and India).
- Technology's threefold role remains in force; "cybersecurity technologies" ≠ only products you buy to defend.

Lecture T05: Foundations — Part 01

Learning focus

- Read information security as three constituents (**network; computer and data; management**) with **policy** at the intersection, mapped onto storage, processing, and transmission.
- Use the **McCumber cube** (NSTISSC / John McCumber) so that no cell of cybersecurity is missed.
- Define **confidentiality, integrity, and availability** the way this lecture defines them, with the Alice–Bob–Eve, CV, and IRCTC examples.
- Recall CIA as the **purpose** of information security even if everything else is forgotten.

Key terms

Term	Meaning in this lecture
Policy (in the diagram)	Intersection/reference that guides security practice and investment decisions
Storage / processing / transmission	The three computing aspects that must be secured
CIA triangle	Purpose of information security: confidentiality, integrity, availability
McCumber cube	3×3×3 model: computing × CIA × (policy, education, technology)
Confidentiality	Intended recipient only (A→B, not C); data collector's duty given consent
Integrity	Data arrives intact: whole, unmanipulated; includes subject's ability to keep it complete/correct
Availability	Intended party can access when needed, as per contract; other side of confidentiality
Redundancy	Extra systems so availability survives a failure
Nines	Contractual availability target (e.g. 99.9999…); more nines cost more

Frameworks / formulas

- **McCumber cells = 3 × 3 × 3.** A manager's checklist: for each combination of (storage|processing|transmission) × (C|I|A), are policy, education, **and** technology in place?
- **Availability vs cost:** higher contracted nines ⇒ more redundancy ⇒ higher cost; **100% ≈ unbounded cost**.
- **Consent chain:** data subject ↔ collector/processor; confidentiality = honour that contract about **who** may see the data.

Distinctions

- Information security is **part of** cybersecurity but, in this foundations block, the two terms are used **synonymously** while CIA is taught.
- Policy is not a poster on the wall: it is the **decision reference** for **how much to invest** and **how much to leave unprotected**.
- Confidentiality is **not** "hide everything"; it is **intended vs unintended** readers, including after interception (encryption).
- Integrity is **not** only "no hacker edited it"; missing updates and **wrong data entry** (DOB) are integrity failures, tied to **access rights of the subject**.
- Availability is **the other side of confidentiality**, not a third unrelated slogan. Unauthorized people must **not** see it; authorized people **must** be able to.
- Reliability engineering's contribution here is specifically **redundancy**, not a new CIA letter.

Exam lines

- Three constituents of IS: network, computer/data, management; **policy** at the centre; map onto store / process / transmit.
- McCumber cube: computing × CIA × (policy, education, technology); do not miss a cell.
- Confidentiality: Alice–Bob–Eve; Aadhaar/consent; classification; encryption so intercept ≠ understand.
- Integrity: intact, complete, unaltered; CV and DOB; subject access to correct "my data."
- Availability: IRCTC; redundancy; SLA nines; 100% can be infinitely expensive.
- Midnight recall: cybersecurity does **CIA**.

Lecture T06: Foundations — Part 02

Learning focus

- Sequence **identification → authentication → authorization**, and place **accountability** when incidents happen.
- Explain why confidentiality needs a **credible identity** before access rights can mean anything (gate, Aadhaar, SIM, email).
- Tell the **Target** story (US retail, Thanksgiving/Christmas **2013**, HVAC vendor, POS) without jumping to solutions.
- Separate **technological** from **managerial** vulnerabilities, then show why the case **ties them together** (authorization, turned-off malware tools, false positives, efficiency vs security).

Key terms

Term	Meaning in this lecture
Identification	Creating credible identity (ID card, Aadhaar number, employee ID, account number)
Authentication	Verification that a person is who they **claim** to be (ID shown, fingerprint, password)
Authorization	Predefined **level of access** by role after authentication
Accountability	After an incident, assign **who is responsible** so action can be taken; needs **logs**
Vulnerability	A weakness (unlocked door, unencrypted RAM, vendor over-privilege)
Exploit	Using a known vulnerability; not every vulnerability is exploited
False positive	Benign activity flagged as malicious; eats efficiency; tempts people to disable tools
False negative	Malicious activity not flagged; "very dangerous"
Efficiency–security conflict	Tight controls stall operations (POS queues); bypass is the shortcut

Frameworks / formulas

- **Confidentiality stack:** identify people → authenticate claims → authorize by mapped roles ↔ classified information.
- **Accountability loop:** incident → logs → responsible role → fix the vulnerability (or it repeats).
- **Defense in depth (as it failed at Target):** authorization/configuration **then** malware detect/report/auto-delete **then** (ideally) logging — each layer bypassed or mis-set.
- **Type 1 / type 2:** false positive vs false negative; **no 100% precise** detector.

Distinctions

- Identification **creates** identity; authentication **checks a claim** using that identity. You cannot authenticate well without valid identities (IIT card will not get you a SIM).
- Password leak means authentication **fails open**; that is why MFA is coming later — not taught in depth here.
- Authorization is **not** "are you in the building?"; it is **what this role may touch** (vendor vs POS).
- Accountability is **not** a fourth CIA letter in this talk; it is **incident responsibility** and **logs**.
- Target is **not** "they had no security." They had Pentagon-scale tools (spelled out more in Part 03); **practice, configuration, and bypass** failed.
- Turning off malware tools because of false positives is **managerial**, even when the box is a technical product.
- Do not dump all vendor access into "a tech bug": it is **authorization**, hence **techno-managerial**.

Exam lines

- ID → AuthN → AuthZ, then accountability with logs when incidents happen.
- Aadhaar: hard identification (vendors, number); later biometric authentication.
- Target 2013, US retail, holiday peak, HVAC vendor, unencrypted POS RAM, encrypted transmission, malware tools off, false positives, efficiency vs security, incomplete logging.
- Vulnerability ≠ exploit; unlocked classroom.
- Breach = combination of technical and managerial failures, especially **authorization** plus **disabled monitoring**.

Lecture T07: Foundations — Part 03

Learning focus

- Assess Target's **tangible** and **intangible** impact (money, lawsuits, holiday profit, goodwill, regulation).
- Reconstruct **what really went wrong** despite CIA-agency-grade tools: vendor access, failed segmentation, **RAM scrapers**, ignored alerts.

- Use the **Titanic / Captain Smith** story and **Andrew Grove's** "paranoid" advice as the managerial moral: **do not ignore safety warnings**.
- State the **watershed** regulatory lesson and the provocative industry quote on investing the **bare minimum** and paying fines later.

Key terms

Term	Meaning in this lecture
Tangible impact	Court settlements / fines / payouts on the order of **$100 million**
Intangible impact	Trust, reputation, opportunity cost, **goodwill**, customer switch to rivals
Network segmentation	Isolating third parties from POS — Target **failed** this
RAM scraper	Malware that taps unencrypted card data from POS memory
Watershed moment	Target as a turning point for **how governments frame breach rules**
Paranoid mindset	Grove: doubt the appearance that "everything is fine"; do not ignore warnings
Bare-minimum position	Invest little in security, treat breaches as a cost of fines if the firm can bear them

Frameworks / formulas

- **Impact split:** tangible (lawsuits, insurance, Visa, customer payouts) + intangible (goodwill, −46% holiday profit, regulatory shock).
- **Scale check:** $100M / $72B ≈ "pickpocket" — used to motivate why some boards **under-invest** unless law or competition says otherwise.
- **Captain's rule:** safety warning → **act**; calm appearance is not evidence.
- **Risk-management preview:** ignore / court / signal / informed deferral — **options**, not yet a full treatment.

Distinctions

- **CIA the agency ≠ CIA the triangle.** Target's tools matched intelligence-agency **protection systems**.
- Compliance and expensive tools **do not** equal safety if **vendor authorization, segmentation, and alert handling** fail.
- Credit **unions** ≠ credit **card companies** in this impact story.
- $100M can be **existentially small** for a $72B retailer **and still** be a **national regulatory** event because **people's data** is at stake.
- Bypassing malware reporting is not a clever efficiency hack; it is **Captain Smith**.
- "Paranoid" is taught as a **professional attitude**, not as clinical language.
- Paying fines after the fact is a **possible management position** only where **regulation and competition** allow it; the EU-style comprehensive law changes that calculus.
- Informed risk-taking (have a plan) ≠ **closing your eyes**; the course will return to this under **risk management**.

Exam lines

- Target impact: ~$100M tangible, >90 lawsuits, holiday profit −46%, goodwill / Walmart, government rewrite of breach rules.
- Cause recap: vendor access + failed segmentation + RAM scrapers on unencrypted POS memory + malware reporting **switched off**.
- They had $1.6M tools, CIA-agency-like systems, audits, card-industry standards — **administrative failure** still produced the breach.
- Titanic: ignored iceberg warnings; aviation: protocols work when not bypassed; Grove: paranoid managers survive.
- US lacked one comprehensive cyber/privacy law; EU had one; boards may choose bare-minimum security if fines are not fatal — unless markets punish the signal.

Contents

Volume 02 — GRC & Contingency Planning **1**
Lecture T08: Security Management and GRC — Part 01 1
Lecture T09: Security Management and GRC — Part 02 3
Lecture T10: Security Management and GRC — Part 03 4
Lecture T11: Contingency Planning — Part 01 6
Lecture T12: Contingency Planning — Part 03 7
Lecture T13: Contingency Planning — Part 02 9
Lecture T14: Live session — Contingency planning Q&A 10

Volume 02 — GRC & Contingency Planning

Cyber Security and Privacy · NPTEL 106106248 · Prof. Saji K. Mathew **notes-3** — concept exam notes (definitions & what things do). Breadth over lab depth.

Lecture T08: Security Management and GRC — Part 01

Learning focus

- Place cybersecurity inside a **management** problem (cyber assets as resources), not only a technology problem.
- Name the three broad approaches to cybersecurity management that the instructor constructs: GRC, standards-driven, and textbook / organizational planning.
- Distinguish **governance** from **management**, and say what it means to attach cybersecurity to governance.
- Map the three GRC frameworks taught here: **COBIT**, **COSO**, and **COSO ERM**.
- List what **internal controls** try to control, and the three control types (preventive, detective, corrective).
- Sketch COBIT 5's split of governance vs management and the Plan–Build–Run–Monitor cycle.

Key terms

Term	Meaning in this lecture
GRC	Governance, Risk and Compliance — broad management/governance framework used in cybersecurity circles
ERM	Enterprise Risk Management — all organizational risk under one frame; cyber is one category
Governance	Higher body than management: institutes management, monitors organizational health, sets direction
Management	C-level and structures that make the organization function toward board-set strategy
COBIT	ISACA GRC standard; IT-based, enterprise end-to-end control (version 5 here)

Term	Meaning in this lecture
COSO	Committee of Sponsoring Organizations; accounting-origin **internal control** framework
COSO ERM	COSO expanded with response, objective setting, identification — risk-based enterprise frame
Internal control	Processes that safeguard assets, records, reporting, efficiency, policy adherence, legal compliance
Preventive / detective / corrective	Three aspects of how internal controls work
APO	COBIT process set associated with **Plan**
SOX	Sarbanes–Oxley — US accounting standard after major scandals

Frameworks / formulas

- **Three management approaches:** GRC (cyber inside ERM) · standards-driven (ISO/NIST on cyber) · textbook organizational planning (strategy + contingency).
- **Three GRC frameworks:** COBIT · COSO · COSO ERM.
- **Internal control types:** preventive, detective, corrective.
- **COBIT 5 management cycle:** Plan → Build → Run → Monitor; governance Direct / Evaluate / Monitor above that.
- **COSO ERM additions:** risk **response**, **objective setting**, **identification**.

Distinctions

- This course is **management of cyber assets**, not a technology course; technology is a constituent.
- **Governance ≠ management.** Governance is the higher body that installs and monitors management. Saying "cyber governance" means cyber is **strategic**, top priority.
- **GRC ≠ ISO/NIST.** GRC frameworks (COBIT/COSO/ERM) are **enterprise-wide**; ISO/NIST (next lectures) are **cybersecurity-specific** standards. A standard can still be used inside GRC.
- **COBIT vs COSO:** IT/ISACA community vs accounting/AAA community. COSO's keyword is **control**; COSO ERM's move is **risk** (assessment **plus** response).
- **Cyber as standalone vs cyber as one ERM risk:** GRC does the latter; standards-driven and small-firm practice often do the former.
- **Training vs education:** ISO/COBIT market courses vs this academic organizational-planning path.

Exam lines

- Wish for the best, prepare for the worst; Pasteur: fortune favors the prepared mind. Incidents (Marriott 500 million, Target, Air India) are growing.
- Three approaches: GRC/ERM, standards (ISO/NIST), textbook strategic + contingency planning.
- GRC frameworks: COBIT (ISACA, end-to-end IT control, Plan–Build–Run–Monitor), COSO (internal control), COSO ERM (adds response, objectives, identification).

- Internal controls: what they control (assets, records, reporting, efficiency, policy, law) and how (preventive / detective / corrective).
- RBI can force cyber as a C-level strategic function in banks; other sectors may have no such mandate.
- Risk in GRC is postponed: later sessions treat cyber-risk assessment and the **five** response options.

Lecture T09: Security Management and GRC — Part 02

Learning focus

- Know when **COSO / COSO ERM / COBIT** are the wrong grain (startup, mid-size) and when **cyber-specific standards** still matter.
- Trace **ISO 27000** from **BS 7799** through **ISO/IEC 17799:2005** to **ISO 27001** in **PDCA** form.
- Explain **Plan–Do–Check–Act** as ISO 27001's improvement cycle (and relate it to COBIT's Plan–Build–Run–Monitor).
- Contrast **ISO** (European, paid, not open) with **NIST** (US, open standards) as the instructor teaches the politics and the adoption puzzle.
- Recap the class reasons why the world is not "all NIST / all open source": **service/support** and **reputation**.
- Know that **iPremier** (Harvard, versions A/B/C, 2018 update) is the day's case; discussion of A continues in T10.

Key terms

Term	Meaning in this lecture
BS 7799	British Standard that originated ISO's cybersecurity management line
ISO/IEC 17799:2005	Large control catalogue (**133** possible controls) before the 27000 rename
ISO 27000 series	ISO family **for cybersecurity management** (>50 standards; verticals and horizontals)
ISO 27001	Basic standard in the family; **PDCA** format; keep the ISMS in an improvement cycle
ISO 27002	"Fundamental" / control-guide standard; 27799 uses it for health
ISO 27799	Information security management **in health**
PDCA	Plan, Do, Check, Act — continual improvement cycle
NIST	US National Institute of Standards and Technology — open technology/cyber standards
Open standard	Freely accessible (NIST as taught here); opposite of paid ISO documents
iPremier	HBS e-commerce DDoS case, versions A/B/C

Frameworks / formulas

- **PDCA:** Plan → Do → Check → Act → (repeat). ISO 27001's shape; cousin of COBIT Plan–Build–Run–Monitor.
- **ISO 27000 map (as taught):** BS 7799 → ISO/IEC 17799:2005 (133 controls) → 27000 series (27001 PDCA core; 27002 guides; 27799 health; plus infrastructure, network, etc.).
- **Adoption choice:** GRC/ERM if large; cyber-specific ISO or NIST if the asset base is cyber / the firm is smaller; both can coexist.

Distinctions

- **COSO ERM / COBIT vs ISO/NIST:** enterprise GRC vs **cyber-specific** standards. Small/online firms may skip ERM; they may not skip ISO/NIST-type practice.
- **ISO vs NIST:** European vs US; **paid/closed vs open**. Preference follows regional politics and military/sensitive-use history, not only technical merit.
- **Having a standard ≠ implementing it.** Open documents still need expertise; free software still needs **service**.
- **Product vs service:** you consume service; that is why proprietary stacks persist.
- **This hour is industry familiarization**, not a full ISO/NIST implementation course. Contingency-planning procedure is deferred to NIST + later lectures.

Exam lines

- Large-firm GRC is optional for a startup; **cyber-asset standards are not optional** if you are online / IT-heavy.
- ISO 27000 = ISO's cyber management family, from **BS 7799**, through **17799:2005 (133 controls)**, to **27001 (PDCA)**.
- PDCA keeps the security system in a live improvement cycle.
- NIST standards are **open** (e.g. computer security handbook); ISO's 27000 documents are **not**. Class reasons ISO still wins: **support** and **reputation**.
- iPremier A is the case vehicle for "what happens when an e-commerce firm has no working GRC/standard/contingency practice."

Lecture T10: Security Management and GRC — Part 03

Learning focus

- Reconstruct the **iPremier** A narrative: who is who, 04:30 timeline, Qdata, missing IR/DR/BCP.
- Define **DoS vs DDoS**, botnets / zombie networks, and the **SYN flood** as used in the case.
- Separate **technical** failures from **managerial** failures (stock-option culture, no cyber strategy, no standards).
- State the **four stakeholder pressures** on CIO Bob Turley and why the instructor treats "resume as usual" as the riskier path.
- Carry the teaching verdict: an e-commerce firm that ignores GRC/ISO-type frameworks and **contingency planning** can go out of business; PR and time-to-restore

are part of the decision, not extras.

Key terms

Term	Meaning in this lecture
DDoS	Distributed denial of service — many systems flood a target so legitimate users cannot use it
DoS	Same aim, **single** source, smaller scale, easier to attribute
Botnet / zombie network	Malware-controlled machines the attacker uses to generate flood traffic
SYN flood	The DDoS form identified on iPremier's **firewall router**, from multiple sites
Qdata	Third-party host; proximity (and personal ties) over competence
BCP binder	Business continuity document they **have** but have **not updated or practiced**
Market Top	Main competitor; switching risk if iPremier goes dark
Catch-22 of the night	Diagnose (needs shutdown) vs survive in a niche online market (needs uptime)

Frameworks / formulas

- **GRC lesson applied:** e-commerce at this scale should have had a **framework or ISO-type standard** plus **IRP/DRP/BCP**. None were live.
- **Decision frame:** four voices (CEO, ops, stock/PR, legal) → one CIO call.
- **DoS ⊂ DDoS** as taught: DDoS is the distributed, multi-source form of DoS.

Distinctions

- This **was** a DDoS, not a "failed attempt." Unknown = whether **intrusion / data theft** rode along (DDoS ⇏ "no intrusion").
- **Technical right ≠ business right.** A long shutdown can **end the firm** in a two-player luxury e-commerce market.
- **Hiding vs disclosing:** later revelation (especially if the rival is the attacker) destroys **high-end trust** more than an honest hit now — but the **wording and duration** of any shutdown statement are the live problem.
- They were **at the attackers' mercy**; the attack **self-stopped**. Without diagnosis you cannot claim corrective/preventive action, so **resume as usual is the more dangerous** operational choice.
- **"How long?"** is the CEO question; "we don't know" is true and **unacceptable**. That is the case's dilemma, not a student failure.
- Preparedness fantasies (hot site, updated binder) are **not available options** at 05:26 if you never invested. The case shows what **lack of GRC + contingency** does to an online business.

Exam lines

- iPremier: luxury e-commerce, trust-critical, stock-option culture, Qdata, logging traded for 20% UX, BCP stale, no IR practice, Joanne locked out, SYN-flood DDoS,

attack stops itself.
- DoS vs DDoS; botnets/zombies; motives include rivalry and extortion.
- Failures: technical (Qdata, firewall, logs) **and** managerial (no cyber strategy, no framework, stock over risk).
- Bob must reconcile CEO uptime, ops shutdown, legal disconnect, and VP stock.
- Instructor: find out why it stopped; PR is part of the decision; B/C will show what happens if you do not shut down.

Lecture T11: Contingency Planning — Part 01

Learning focus

- Split cybersecurity planning into **organizational (preventive)** vs **contingency (reactive)** — different objectives.
- Use **iPremier** (and **IVK**, **Target**, **Saudi drone**) to show what "no plan" does to people and to **ROI arguments** for security spend.
- Align security plans with **strategic / tactical / operational** business plans (and correct the textbook's order).
- Classify incidents by **impact** into **IRP**, **DRP**, and **BCP**, including the site-shift rule for BCP.
- Trace the instructor's incident picture: **assets → vulnerabilities → exploit → incident → impact → contingency action**.

Key terms

Term	Meaning in this lecture
Contingency planning	Reactive: restore to normal **in minimum time** after an incident
Organizational planning	Preventive: strategic / tactical / operational plans that **protect**
IRP	Incident response plan — **low** impact; operations continue
DRP	Disaster recovery plan — **high** impact; restore **without** changing site
BCP	Business continuity plan — impact so high you **relocate**
IDS	Intrusion detection system — capital item finance wants ROI for
Vulnerability	Gap in walls/firewalls that can be exploited
Exploit	How a hacker uses a particular gap
Incident	Attack that **actually happened** (after intrusion)
Emotion-focused coping	Yelling / fleeing / wishing when there is no plan (Gilbert)

Frameworks / formulas

- **Preventive vs reactive** planning split.
- **Strategic (3–5 yr) → tactical → operational** (textbook order corrected).
- **Impact → IRP / DRP / BCP.**

- **Investment rationale for controls:** not new revenue; **cost avoided » spend**. Quantify legal, sales hit, downtime, recovery. Dynamic, not one-time. Proportional to risk (later module).
- **Incident chain:** assets → vulnerabilities → exploit → incident → impact class → plan type.

Distinctions

- **Contingency ≠ risk-management planning.** One is **after** the incident (restore); the other is **so the incident does not happen** (protect). Both are required.
- **IRP ≠ DRP ≠ BCP.** Same family, **different impact**. BCP is the one that **moves the organization off site**. DRP is severe but **same location**.
- **Textbook's planning-level order is wrong**; use time range: strategic, then tactical, then operational.
- Security spend is **cost reduction**, not a new revenue stream. Finance will not buy qualitative fear; IVK shows the **articulation** failure.
- **Doing nothing is not an option** even when numbers are soft (no mature cyber insurance).
- Protection (shoe knurls) does **not** mean zero incidents. Contingency exists **because** residual gaps remain.

Exam lines

- Contingency = reactive restore-at-earliest; organizational planning = preventive, aligned to business goals (Franklin; JFK "and back safely").
- No plan → emotion, blame, job-protection (iPremier, Gilbert).
- IVK: IDS has no classic ROI; quantify **avoided cost**; seniors must learn that.
- IRP / DRP / BCP chosen by **impact**; BCP = cannot operate here (Chennai floods).
- Incident = exploit of a vulnerability against an asset; then classify low/medium/high and act.

Lecture T12: Contingency Planning — Part 03

Learning focus

- Carry Part A into **B**: public disclosure, 75-minute DDoS, file-name checks that **do not** prove integrity, Ripley's 24–36 hour rebuild.
- Explain why **keeping the old site live while building a new one** is the business-friendly option and still **technically unsafe**.
- Follow **Part C**: no comprehensive shutdown → **FBI** call that iPremier is attacking **Market Top** from a production host → firewall **was** penetrated ("fire suppressed during the retreat").
- Use the instructor's corrections: do not compare **Google/Microsoft** competence with **Qdata**; a new site without **updated firewall/IDS** repeats the failure.
- List the team's mitigation map (CDN, scale, DDoS services, CPMT, IRP/DRP/BCP, CIA **availability**) without treating it as a substitute for the case's **catch-22**.

Key terms

Term	Meaning in this lecture
File identity and size check	Proves names/sizes exist; **does not** prove contents or extra malware files
Development files	Build source treated as **less likely tampered** than production
“Fire suppressed during the retreat”	Apparent stop of the DDoS hiding a **planted** capability
Credit-card processing agreement	Separate lawsuit path if numbers were stolen
CDN	Distributes flood traffic so one origin is not the only choke point
Defence in depth	Different controls per layer (team’s Google 3–4 vs 6–7 reading)
CPMT (NIST 7-step)	Contingency committee the firm should have had **before** 04:30
Catch-22	Forensics need darkness; the market needs light

Frameworks / formulas

- **Reactive vs proactive** (B’s post-attack shopping list vs Google’s pre-built Armor).
- **IRP / DRP / BCP** restated by the team: during / after / parallel-run — matching T11–T13, applied to a firm that had none.
- **CIA:** availability first casualty (ops locked out of the host).
- **Cost vs time** on the rebuild decision (instructor: both, plus **technical viability**).

Distinctions

- **Presence of files ≠ integrity of files.** Without content verification you do **not** know there was no intrusion.
- **Option 2 is not “we will be ready next time.”** It is **running the unknown-bad production site until a future date.** Hackers do not wait on your project plan.
- **Shutdown needed for forensics** vs **shutdown as customer suicide** — the case does not dissolve that tension; Part C shows what “no shutdown” **became**.
- **Do not copy hyperscaler playbooks onto Qdata.** New site without **new firewall + IDS** is the same vulnerability with a new label.
- A parallel server **on the same stack** is not by itself a DDoS answer; **separating payment data** is the more serious architectural hint from the floor.

Exam lines

- B: public DDoS admission (75 min); name/size audits; Ripley 24–36 h rebuild vs live-old + new-site (~3 weeks); logging had been a 20% UX trade.

- C: they stay up; two weeks later FBI says iPremier is the attacker; planted file on production; Market Top and card-brand legal risk; rebuild now looks like evidence tampering.
- Theory applied: hot site, CPMT, IR/DR/BCP, simulated attacks — all **after** the fact.
- Instructor: diagnose the unknown; don't pretend Google's night is iPremier's night.

Lecture T13: Contingency Planning — Part 02

Learning focus

- Put a **CISO** (and RBI's separate security role) on the organizational-planning side, then switch to contingency.
- State the **goal of contingency planning** and the job of the **CPMT**.
- Run **business impact analysis (BIA)** on **business processes** (not assets), using **MTD, RTO, WRT, RPO**.
- Use the **cost-of-disruption vs cost-of-recovery** graph; name the intersection as the management negotiation for time.
- Switch **IRP → DRP → BCP** by impact and by **who leads**; keep **DR = same/primary site**, **BCP = change site**.
- Know IR **before / during / after**, Pipkin's indicators, **GDPR 72-hour** reporting, **hot/warm/cold** (and time-shared) sites, and **red/blue/purple** tests.

Key terms

Term	Meaning in this lecture
CISO	Chief information security officer; reports to CIO; policy, plans, budget, monitor, law, incident comms
CPMT	Contingency Plan Management Team/Committee — oversight of CP and subcommittees
BIA	Business impact analysis — process-level impact; sets the clocks
MTD	Maximum tolerable downtime — **process owner**
RTO	Time to **system live** — technical
WRT	Time to **operations** after the system is live
RPO	How far back you can recover — **backup policy**
Redundancy	Extra capacity (hot/warm site) that buys short MTD at high recovery cost
Hot / warm / cold site	Parallel-ready / make-ready-in-time / slowest alternate location
Pipkin indicators	Possible / probable / definite signs an incident has occurred
After-action review	Post-event: did the process improve or worsen?

Frameworks / formulas

- **MTD = RTO + WRT** (RPO separate, from backup cadence).

- **BIA unit = business process**; **risk unit = asset**.
- **Cost trade-off:** disruption cost ↑ with downtime; recovery cost ↑ as target downtime ↓; **optimum at intersection**.
- **IRP (tech) → DRP (CIO, same site) → BCP (CEO, new site)** by impact.
- IR: before / during / after; document what–when–where–why–how.
- GDPR: report in **72 hours**.
- Test with red / blue / purple.

Distinctions

- **CISO ≠ CIO.** Banks (RBI) must have both; CISO owns the security **policy/plan** track.
- **BIA ≠ risk assessment.** Processes vs assets.
- **MTD is not a tech number.** Process owner sets it; tech fits RTO+WRT inside it. **Zero MTD** is ideal and **unusable** without paying recovery cost.
- **Downtime cost ≠ restoration cost.** Fast restore requires **redundancy spend**. CP is **negotiation for time**.
- **DR vs BCP (site rule):** DR recovers **at the primary site**; BCP is when you **cannot stay** and **move**. Naming is awkward (BCP is a process name, not an event name).
- **Threat vs incident.** Threats are potential; incidents have happened; you still need logs/IDS to **know**.
- **Hide vs law:** GDPR removes the "contain it internally" option on the EU facts.

Exam lines

- CISO reports to CIO; writes policy/plans/budgets; RBI wants this role in banks.
- CPMT restores to normal **at minimum cost**; BIA on **processes** sets **MTD, RTO, WRT, RPO** with **MTD = RTO + WRT**.
- Draw the two cost curves; manage at the **intersection**; that is "earliest."
- IR → DR (same site, CIO) → BCP (relocate, CEO).
- Hot/warm/cold; Pipkin indicators; GDPR 72 hours; red/blue/purple to keep the binder from becoming iPremier's.

Lecture T14: Live session — Contingency planning Q&A

Learning focus

- Restate contingency as **planning for the unexpected**: CPMT restores to **normal operation in minimum time**.
- Hold both costs: **downtime vs restoration/redundancy**; optimum at the **intersection**.
- Use the instructor's **on-the-spot correction**: **DR = recover at the same location**; **BCP = you must relocate**.
- Distinguish **vishing** (malicious **voice** calls) from **phishing** (malicious **email**).
- Apply textbook roles: **data owner**, **data custodian**, **data user / subject**.
- Treat **technological and managerial vulnerabilities as intertwined** (Target LAN, iPremier logging, Equifax governance).

Key terms

Term	Meaning in this lecture
Management	Managing **resources** (people, money, land, materials, technology)
Contingency	Unpredictable incident; plan for the unexpected
CPMT	Team whose role is restore to normal **in minimum time**
Cost trade-off	Downtime cost vs restoration/redundancy cost; optimum at intersection
IR	Lower-impact incident (e.g. one machine)
DR	Recover from a severe event **at the same location**
BCP	**Cannot** operate here; **move out**
Phishing	Malicious **email**
Vishing	Malicious **voice call** (phone-channel phishing)
Data owner	Senior management; security/use; **classification**
Data custodian	Operational; systems that process/transmit/store (e.g. DBA)
Data user / subject	Person whose data is stored (students; privacy "subject")
People–process–technology	The IS breakup; all three carry vulnerability

Frameworks / formulas

- Planning vs no planning → **higher cost / inefficiency**.
- Contingency **reactive**; risk management **later / protective**.
- **Shorter downtime target ⇒ higher restoration cost** (redundancy).
- **DR same site / BCP relocate** (after the spoken correction).
- **People, process, technology**; managerial cause → technical symptom.

Distinctions

- **He misspoke, then corrected:** moving plant because the site is dead is **BCP, not DR**. **DR = same location.** Learn the correction, not the first sentence.
- **Zero downtime ≠ free.** You pay in **redundant systems**.
- **Phishing ≠ vishing.** Email vs **voice**.
- **Owner ≠ custodian ≠ user.** Senior classification vs operational DBA vs the person in the database. Do not use the words loosely.
- **Tech vulnerability vs managerial vulnerability:** often **one event with two layers** (LAN misconfig is what was exploited; **who configured it** is management). Logging off is a **decision**, not a mysterious technical fate.
- **Best technology ≠ no breach** (Target). Later, **governance** can fail too (Equifax).
- Contingency is required **even if** risk management and controls were done.

Exam lines

- Management = resources; planning cuts loss. Contingency = paradox of planning the unexpected; CPMT restores **earliest**, subject to the **two-cost** intersection.
- IR small; **DR same site**; **BCP relocate** (instructor's apology is the rule).
- Phones: malware and **vishing**; email **phishing**.

- Owners (senior, classify), custodians (operational systems), users/subjects (whose data).
- Target/iPremier: people and technology **together**; standards/processes are what reduce those errors.

Contents

Volume 03 — Policy & Risk Management **1**
Lecture T15: Cybersecurity Policy — Part 01 1
Lecture T16: Cybersecurity Policy — Part 02 2
Lecture T17: Cybersecurity Policy — Part 03 4
Lecture T18: Cybersecurity and Privacy — Extended Discussion (live) 5
Lecture T19: Risk Management — Part 01 6
Lecture T20: Risk Management — Part 02 7
Lecture T21: Risk Management — Part 03 8

Volume 03 — Policy & Risk Management

Cyber Security and Privacy · NPTEL 106106248 · Prof. Saji K. Mathew **notes-3** — concept exam notes (definitions & what things do). Breadth over lab depth.

Lecture T15: Cybersecurity Policy — Part 01

Learning focus

- Treat policy as the **reference document** that planning and day-to-day security decisions go back to.
- Separate **norm**, **policy**, and **regulation** (law).
- See policy as something that can **enable** or **disable** an organization, and that **changes behavior** at country, firm, and individual levels.
- Apply the first formation rule: a policy must **never conflict with the law** and must **stand up in court**.
- Hold both sides of the trade-off the instructor keeps repeating: **protect** without blocking **progress**.

Key terms

Term	Meaning in this lecture
Policy	Binding reference document so the organization can meet objectives with fairness; not only for one person
Social norm	Unwritten expectation (dress for class); not court-enforceable
Regulation / law	Legally enforceable rule; someone can take you to court
Shredding / retention policy	How long documents are kept; must be specific enough to survive court
Due diligence (implementation)	Stating the rule is not enough; firewalls and admin must actually carry it out
Protect vs progress	Safety controls vs the organization's ability to work; policy has to balance both

Distinctions

- **Norm is not regulation.** Dressing for class is a norm; law is what a court can enforce.
- **Policy is not automatically law.** It becomes regulation only if it is legally enforceable.
- **A convenient policy is not a lawful policy.** Andersen's "till it is relevant" was a policy that conflicted with the law.
- **Framing ≠ implementation.** "Employees must not visit illegal sites" is weak in court if the firewall still lets them through.
- **Individual fault does not automatically clear the organization.** Without a policy and due care, the org is still in the argument.
- **More restriction is not automatically better policy.** A policy that blocks work will be violated.

Exam lines

- Policy is the reference that tells you cybersecurity is a priority and how people must behave; without it there is nothing to refer to in a crisis.
- Policy can enable (India IT) or disable (no document, or a document that makes work impossible).
- Quote-level balance: protect privacy **without inhibiting** digital technologies.
- First principle: **do not contradict the law**; use measurable retention rules, not "till relevant."
- For internet misuse: written policy **and** blocking/implementation; both employee and organization can be responsible.
- Behavior change is the point: well-framed policy invites compliance; fear-only or unusable policy produces violation or inefficient compliance.

Lecture T16: Cybersecurity Policy — Part 02

Learning focus

- Separate **policy, standards, procedures, and guidelines**.
- Use the three-level hierarchy the lecture treats as standard terminology: **EISP**, **ISSP**, **SysSP**.
- Treat policy as a **long-term master document**; put changing legal detail in standards/procedures.
- Explain **SETA** and why dissemination is a management duty.
- Map SysSP onto **management guidance** plus **technical specification** (ACL and configuration rules).
- Distinguish **firewall (prevention)** from **IDS (detection)**.

Key terms

Term	Meaning in this lecture
EISP	Enterprise Information Security (Program) Policy — top, strategy, scope, tone, roles
ISSP	Issue-Specific Information Security Policy — technology/issue level; can indemnify the organization
SysSP	System-Specific Information Security Policy — management guidance + technical specs
SETA	Security Education, Training and Awareness
Indemnify	Absolve of responsibility; ISSP is written so the **organization** is protected in typical IT abuse cases
ACL	Access control list: roles × resources × privileges × when/where/how
Firewall	Preventive control of traffic in and out
IDS	Intrusion detection — alarm, not prevention
Tone	Word choice in EISP ("critical" vs "due importance") that signals resource commitment

Distinctions

- **Policy ≠ procedure.** Policy is the long-term reference; firewall rules are procedures.
- **Do not rewrite EISP when a statutory clock changes.** "Comply with the law" stays; the hour-count lives in standards.
- **EISP is not ISSP.** Enterprise document talks mission and roles; ISSP talks email/cloud/WFH and monitoring.
- **Indemnifying the organization is not the same as indemnifying employees.** Medicine often indemnifies doctors; this ISSP discussion is about protecting the firm from employee misuse.
- **Stated policy without SysSP implementation fails in court.**
- **Firewall is not IDS.** One prevents; one detects.
- Job titles on the org chart (**Director–IT**) may be wrong even when the **EISP/ISSP/SysSP** concepts still apply.

Exam lines

- Hierarchy to memorize: **EISP → ISSP → SysSP**, with email as the stock example (facility → use rules → 5 GB config).
- SETA is how policy actually reaches people; this course is the **E**.
- ISSP is also a **legal** document (monitoring notice + indemnification).
- SysSP = guidance document + ACL + configuration (firewall/IDS).
- Policy is stable; standards move when regulation's details move.

Lecture T17: Cybersecurity Policy — Part 03

Learning focus

- Restate the article's claim: **spending on cyber defense does not guarantee** you will be shielded.
- Define **critical infrastructure** as the lecture's student group used it, and why coupling across sectors raises consequence.
- Contrast **cyber hygiene** with what a **determined attacker** can still do.
- Use Idaho National Laboratory's **CCE** and **CIE** as a policy-relevant alternative to "buy more tools."
- Carry forward the sentence the instructor underlines at the end: **any system connected to the internet is not secure.**

Key terms

Term	Meaning in this lecture
Internet insecurity	Article's frame: connected systems are not secure; "cybersecurity spend" is the wrong guarantee
Critical infrastructure	Energy, telecom, critical manufacturing, transport, water; now interdependent grids
Cyber hygiene	Routine scanning, patching, training, segmentation, password discipline — necessary, not sufficient
CCE	Consequence-Driven Cyber-Informed Engineering — start from worst consequence, then cut digital paths
CIE	Cyber-Informed Engineering — include cyber as a failure mode from conceptual design
Crown jewel	The function whose loss jeopardizes the whole operation
Air gap	Keep the redundant / critical path off the internet so backup is not hit with the primary

Distinctions

- The series title is **insecurity**, not security — that is the point.
- **More spend ≠ guaranteed protection.**
- **Hygiene ≠ survival against a dedicated attacker.**
- **CCE is not "abandon automation."** It is redundancy and less digital exposure for the crown jewel.
- **Do not air-gap the primary and then network the backup.**
- Cyber should be treated as an engineering **failure mode**, not an IT afterthought (firewall later).
- **Capability and vulnerability rise together** in digital transformation.

Exam lines

- Quote-level claim to remember: a system on the internet is **not secure**.
- Critical infrastructure is **coupled**; one failure can cascade.

- Hygiene (patches, training, segmentation) is the floor; INL's answer is **consequence-first** design and **reduced digital pathways**.
- CCE four steps and the crown-jewel language are the article's method.
- Next case (**Protecting the Cheddar**) is how this argument looks inside a factory.

Lecture T18: Cybersecurity and Privacy — Extended Discussion (live)

Learning focus

- Expand **BIA** as asked in chat: **Business Impact Analysis** (Week 4, contingency planning).
- Place **policy** between contingency planning and risk management: policy **guides** risk work.
- Restate policy as the instrument that makes **desired behavior** appear — national, organizational, individual.
- Keep the internet-insecurity claim in decision language: **what you connect and what you don't**, once you accept that connected systems are insecure.
- Know the Week 5 reading the instructor actually assigned (textbook chapter and the HBR article).

Key terms

Term	Meaning in this lecture
BIA	**Business Impact Analysis** — Week 4 contingency-planning assessment (full form as given in this live session)
Policy (behavior)	The document **and its implementation** that produce desired (including compliant) behavior
Levels of policy	Same intent at different abstraction: strategy/priorities down to firewall rules
Critical infrastructure	What must keep running for a country or a firm (health, energy, finance named)
Internet insecurity	Connected ⇒ insecure; policy is choosing what stays on the network

Distinctions

- **Content questions vs platform rules.** This session is for the former.
- **PG class ≠ UG textbook recitation.** Cases and HBR are mandatory advanced material, not decoration.
- **iPremier is not a topic change**; it is contingency planning in a real incident.
- **Policy on paper is not behavior change** unless communicated and implemented.
- **Disconnecting from the internet is not free** — you trade efficiency for a smaller attack surface.
- This course is **knowledge / concepts**, not CEH-style skill training.
- **BIA** in this Q&A is the **name** of the Week 4 analysis, not a new formula lecture.

Exam lines

- **BIA = Business Impact Analysis** (contingency planning, Week 4).
- Policy week sits **between** contingency and risk because policy is the reference that **guides** risk management.
- Desired security behavior does not "evolve" without policy that is **known and implemented**.
- Critical infrastructure must be **identified** before it can be prioritized; connected infrastructure is **insecure** by the article's observation.
- First professional question: **what is the policy?**

Lecture T19: Risk Management — Part 01

Learning focus

- Contrast **contingency planning** (reactive; unit = **business process**) with **risk management** (preventive; unit = **assets**).
- State risk management as **identifying, assessing, and reducing** risk — **not eliminating** it.
- Use Sun Tzu's pair **know the enemy / know yourself** as the frame for threats vs assets and preparedness.
- Explain **residual risk** as leftover risk after base safeguards, extra safeguards, and remaining vulnerabilities.
- Walk **risk identification**: six asset categories, tagging/database, classification, and **business-impact** valuation (not purchase price).

Key terms

Term	Meaning in this lecture
Risk management	Identify, assess, **reduce** risk to cyber assets (not eliminate)
Know yourself	Assets + current preparedness
Know the enemy	Threat intelligence (internal and external)
Attack	Threat that has exploited leftover vulnerability
Attack surface	Two-dimensional view: threats × assets (sometimes loosely called vector)
Residual risk	Leftover risk after base safeguards, extra safeguards, and remaining vulnerabilities
Loss frequency	Probability-side measure (introduced here; formula next lecture)
Loss magnitude	Impact-side measure; function of **business** value of the asset
Asset valuation	Weighted business-impact score, not invoice cost
Security clearance	Person's authorized access class

Distinctions

- **Contingency ≠ risk management.** Process unit vs asset unit; reactive vs preventive.
- **Reduce ≠ eliminate.** Internet-connected devices have no 100% guarantee. **Reduce** vs **mitigate** will be nuanced later.
- **Residual risk is what you actually manage**, because some protection already exists.
- **Attack surface is not "list of threats."** It is threats **with** assets.
- **Vector** implies **more than one dimension** — do not use the word emptily.
- **Asset value ≠ purchase cost.** SSL order channel at 100 is about stopping the business.
- **Unclassified ≠ sensitive-but-unclassified** in the military scheme they discussed.
- Risk management is **not** a five-year plan you finish.

Exam lines

- RM = identify, assess, reduce; object is **residual risk**.
- Know yourself (assets, preparedness) and know the enemy (threats).
- Six asset categories include **people and procedures**, not only hardware.
- Classify people and data; value assets with a **business-impact** instrument.
- Next lectures: threats, TVA worksheet, then the residual-risk **formula**.

Lecture T20: Risk Management — Part 02

Learning focus

- Identify and **classify** threats; treat **threat intelligence** as **external** data.
- Place **vulnerability on the threat–asset pair**, not on "the firm" in the abstract.
- Use the **TVA worksheet** (threat–vulnerability–asset) as the assessment instrument.
- Compute **loss frequency** and **loss magnitude**, then **residual risk**.
- Record the **in-video four-term formula**, the **worked example that dropped current controls**, and the **instructor's later correction** that removes the mitigated-controls term.

Key terms

Term	Meaning in this lecture
Threat intelligence	External, subscribed, dynamic scoring of threats
Espionage	Insider (or former insider) leaking against the organization/country
Technological obsolescence	A threat class: running critical work on un-updated platforms
Vulnerability	Gap **for a specific asset against a specific threat**
TVA worksheet	Spreadsheet of threats × assets with vulnerability in each cell
Loss frequency	P(attack) × P(success)

Term	Meaning in this lecture
Loss magnitude / exposure	Asset value × % lost in a successful attack
Measurement uncertainty	Worst-case add-on from estimate error
Residual risk	Leftover risk after you have combined LF, LM, (and originally current controls,) plus uncertainty

Distinctions

- **Asset valuation is internal; threat intelligence is external.**
- **Vulnerability is not a free-floating property of the company.** It is a **cell** in TVA.
- **Likelihood of attack ≠ likelihood of success.** Frequency uses **both**.
- **Exposure is not always 100%** of asset value.
- **LF × LM is not the whole residual-risk story** until you add **measurement uncertainty** (worst case).
- **Minus current controls** was taught, then **removed**: do not treat that subtraction as the working formula after the correction; controls are already inside success-probability / vulnerability if assessment is done in place.
- Quantitative is the textbook method; **qualitative is what many shops actually do** because the numbers are hard.

Exam lines

- TVA: threats on one axis, assets on the other, vulnerability in the cell; sort so the **diagonal** is hottest.
- LF = 0.1 × 0.5 = 0.05; LM = 50 × 0.8 = 40; product = 2; +25% uncertainty = **2.5**.
- Remember the **correction**: residual risk = **LF × LM + measurement uncertainty** (no mitigated-controls term).
- Next: what the organization **does** with those numbers (control).

Lecture T21: Risk Management — Part 03

Learning focus

- Apply the **internet-insecurity / CCE** argument to an industrial plant, not only to "IT."
- Reconstruct **Protecting the Cheddar** (Newhouse Cheese): ransomware, recipes, temperature control, $6 million already spent.
- Use the consultant's **four-step** plan as the same crown-jewel method as CCE.
- Hold the class debate: **full rollback vs in-between** (critical functions off the open digital path).
- Hear the instructor's stakes: **listeria / lives**, **ransomware-as-a-service**, **WannaCry / NotPetya**, and Industry 4.0 / IoT.

Key terms

Term	Meaning in this lecture
Protecting the Cheddar	HBS-style case: cheese manufacturer, ransomware, digitized process control
Thermization	Process Jack wants **completely offline**
Digital terrain	Hardware, software, network, human interaction, supply chain around a process
RaaS	Ransomware as a service — criminals buy the tool
Listeria	Food-safety catastrophe if temperature/composition controls are subverted
Least privilege / compartmentalization	Mixed-system argument: a breach should not see the whole plant
Sunk cost	Digitization money already spent; not a reason the consultant accepts to stay fully online

Distinctions

- **Paying $6 million for tools ≠ fewer breaches.** Same lesson as the HBR spend charts.
- **Jack is not selling the Stone Age.** He is selling **fewer digital pathways** to crown jewels.
- **Ransomware scare vs listeria:** in food ICS, **integrity of the process** can be a **life** issue, not only an IT issue.
- **Manual control ≠ automatically safer** — human error was why they automated.
- **NotPetya ≠ "pay and recover."** Payment may not restore the machines.
- Industry 4.0 gains and this class of risk **arrive together**.

Exam lines

- Cheddar storyline: pay **$49,999**, $6M already spent, recipes + temperature ICS, consultant maps terrain and pulls **critical** processes toward **offline / human backstop**.
- Four steps to memorize with CCE: crown jewel, digital terrain, likely path, mitigation options.
- Class/instructor landing zone: **in-between**, not total disconnect and not "business as usual online."
- Ransomware (including RaaS, WannaCry, NotPetya) is **high** in threat intelligence for industrial control; consequence can be **lives**, not only coins.
- Formal **risk-control menu** is deferred; **industry session** is next.

Contents

Volume 04 — Industry, Tech & Privacy Foundations **1**
Lecture T22: Industry Perspective — Part 01 1
Lecture T23: Industry Perspective — Part 02 3
Lecture T24: Live Session — Residual Risk, TVA, and Technology-Week Readings 4
Lecture T25: Cybersecurity Technologies — Part 01 6
Lecture T26: Cybersecurity Technologies — Part 02 7
Lecture T27: Foundations of Privacy — Part 01 9
Lecture T28: Foundations of Privacy — Part 02 10
Lecture T29: Foundations of Privacy — Part 03 11

Volume 04 — Industry, Tech & Privacy Foundations

Cyber Security and Privacy · NPTEL 106106248 · Prof. Saji K. Mathew **notes-3** — concept exam notes (definitions & what things do). Breadth over lab depth.

Lecture T22: Industry Perspective — Part 01

Learning focus

- Explain why a cooperative, trust-based internet makes security structurally hard.
- State the five principles the guest uses for a working cybersecurity system (CIA plus accountability and auditability).
- Describe operating-system rings, symmetric vs public–private cryptography, and hash functions as taught.
- Trace how a packet is unwrapped (MAC → IP → port → application) and why TCP and UDP differ.
- Sketch a corporate perimeter (firewall layers, DMZ, proxy) and the two routes an attacker actually uses.

Key terms

Term	Meaning in this lecture
Cyberspace	Connected, interacting systems; built on cooperation and trust
BGP	Big internet route servers; trust “I know the path” without challenge
CIA + 2	Confidentiality, integrity, availability, plus accountability and auditability (non-repudiation)
Logic bomb	Hidden trigger in software (pipeline story)
No war, no peace	Constant conflict without declared war — the guest’s description of cyberspace
OS	Interface human ↔ compute / I/O; the space where battles are fought
Ring 0	Hardware executes all commands; kernel wants this
Symmetric crypto	Same key to lock and unlock; key distribution and later full-history decrypt

Term	Meaning in this lecture
Public / private key	Public locks for a recipient; only their private key unlocks
Hash	One-way, avalanche on one-bit change; integrity / forensics / download checks
MAC / IP / port	NIC identity, network identity, process identity
TCP	Reliable, sequenced, slow by design (acks)
UDP	Fire-and-forget; OK to lose packets for media
LDAP / Kerberos / RADIUS	Unique identification of people on the network
Firewall	Guard at entry/exit implementing strict rules at chosen OSI intelligence
DMZ	Perimeter zone; in this talk, where an intruder hides after a wall crack
Proxy	Records identity; connects networks without treating them as one
Social engineering	Fool a person and skip the technical wall

Distinctions

- Cyberspace insecurity is not only "bad people"; **protocols assume cooperation**.
- A cybersecurity definition is empty unless it names **CIA + accountability + auditability**.
- Published attack statistics are **not the full crime volume** (20–30% reported).
- **Ring 0 vs user space:** thieves want the watchman's cap, not a noisy user-space crime.
- Symmetric shared-key is not just "weaker math"; **you cannot safely ship the key**, and a later key theft decrypts **old** traffic.
- Hash is **not encryption**: you cannot reconstruct data from the digest.
- TCP vs UDP is **reliability vs loss-tolerance**, not "TCP is always better."
- Firewall layers differ by **how much of the packet they inspect**, not by the slogan "block bad guys."

Exam lines

- Trust is the design of the internet (BGP as the extreme); catching rogues is the core challenge.
- Five principles, not only the triad; auditability = non-repudiation.
- First taught "cyber" strike: Cold War **logic bomb** in pipeline-control software.
- OS + applications are the battlefield; **rings** are hardware privilege; kernel wants ring 0.
- Symmetric key: share problem + later total compromise. Asymmetric: public lock, private unlock.
- Hash: one-way, one-bit avalanche, integrity check (MD5 on downloads).
- OSI unwrap: MAC → IP → port; TCP three-way reliability vs UDP streaming.
- Identify people with LDAP/Kerberos/RADIUS; filter packets with layered firewalls;

expect attackers to **sit in the DMZ** after a perimeter hole — or to **phish an employee** and skip the hole.

Lecture T23: Industry Perspective — Part 02

Learning focus

- Explain VPN as a private encrypted tunnel — and why fooling the VPN server is "key to the kingdom."
- Walk the **cyber kill chain** using the Uri commando analogy.
- Separate spray-and-pray crime from focused cyber espionage.
- Define Trojan vs malware, phishing vs spear phishing, C2, DoS vs DDoS, and vulnerability vs exploit vs payload.
- Describe RAT markets, stealers (Vidar), Qbot staging, APTs, the 3 Ds, and the SideCopy / fake `mail-gov.in` campaign.

Key terms

Term	Meaning in this lecture
VPN / VPS	Encrypted tunnel; VPS assigns a private IP so you look on-LAN
Kill chain	Recon → weaponize → deliver → exploit → payload / persist → C2 → act
Trojan	Malware type whose primary job is a **back door** (payload in a payload)
Spear phishing	Researched, one-target phishing
C2 / C&C	Separate machine that pings "alive?" and issues commands
DoS / DDoS	Overwhelm a service; distributed = many sources, volumetric
Vulnerability	Weak link (not automatically exploitable)
Exploit	Weapon that actually breaks through that link
Payload	What runs after the break (often a RAT); deadliest piece
RAT	Remote administration tool; legitimate or criminal
Stealer	Malware that harvests site passwords (Vidar)
Qbot	Random-email → zip/macro → staged Trojan → botnet monetization
APT	Advanced, persistent, will not walk away; expensive to run
3 Ds	Disrupt, degrade, destroy (plus steal/espionage as motive)
Cryptojacking	Hijack machines to mine, or hijack a wallet
SideCopy	APT (Pakistan-affiliated in this talk) using lookalike gov mail tools

Distinctions

- VPN is not "privacy from your ISP" in this lecture; it is **how branches join HQ** — and the **single best impersonation target**.
- Random crime and espionage are **different weapons and different risk of getting caught**, not two names for the same email.
- Malware ⊃ Trojan; a Trojan **can** become ransomware.

- Phishing vs spear phishing is **targeting and research**, which itself tells you motive.
- DoS vs DDoS is **one source vs many**; both are about **capacity**, not clever credentials.
- A vulnerability is not an exploit; an exploit is not the payload. **The payload is the deadliest.**
- Genuine remote-admin tools and criminal RATs share the idea; the market sells **undetectable, subscription-updated** variants.
- Zip attachments exist to **desynchronize what the mail scanner saw from what the user runs**.

Exam lines

- Fool the VPN server = sit on the office LAN with a private IP; weakest VPN in the mesh is the mesh.
- Kill chain = commando raid: recon, right weapon, exploit, payload, C2 callback.
- Spray-and-pray builds botnets from spam; espionage is expensive, focused, and allergic to hitting a researcher.
- Learn V–E–P, C2, Trojan-as-backdoor, spear phishing as a motivation signal, volumetric DDoS.
- RATs are cheap, licensed against AV; stealers (Vidar) siphon passwords from zip-sized droppers.
- Qbot: zip → macros → staged DLL → C2 chooses ransom or ads; social engineering says “don’t call, reply here.”
- APTs do not leave; vaccine-theft and SideCopy fake-gov-app are the Indian-facing examples; think disrupt / degrade / destroy plus steal.

Lecture T24: Live Session — Residual Risk, TVA, and Technology-Week Readings

Learning focus

- Restate the **risk management process** as identify → assess (measure) → control.
- Compute **residual risk** with the **corrected** classroom formula (no “controls subtracted twice”).
- Unpack **loss frequency** and **loss magnitude** into the two probabilities and the impact × exposure story.
- Draw a **TVA** worksheet (threats × assets → vulnerability) and say what you do after you sort it.
- Know that **chapters 6–8 are to be read together** for the cybersecurity-technology weeks, even if the weekly split looks neater on paper.

Key terms

Term	Meaning in this lecture
Assessment	**Measurement**, not a vague essay about risk

Term	Meaning in this lecture
Residual risk	Risk left in the measure: **LF × LM + measurement uncertainty** (corrected)
Loss frequency	P(attack) × P(success | attack); P(success) from **vulnerability** / existing defense
Loss magnitude	Impact of a successful attack, including **% of the asset exposed**
Measurement uncertainty	Added slack because expert/perceptual measures err; **worst-case step-up**
Threat intelligence	Expert (often external) source of likelihood-of-attack data
TVA	Threats × assets worksheet; cell = vulnerability; then likelihood of success
Chapters 6–8	Technology weeks; read as **one block**, not three isolated weeks

Distinctions

- **Control follows measurement.** No number, no control.
- **Likelihood of attack ≠ likelihood of success.** You can be a popular target and still a hard target.
- **Exposure ≠ "the whole box died."** Part of a system can be down.
- Residual risk in **this** hour is **not** "LF × LM − current controls + uncertainty." Current controls are **already inside** LF (via P(success)) and LM if you assessed honestly. Adding a minus term **double-counts** and confused the class.
- Measurement uncertainty is **not** a confession of ignorance to hide; it is a **deliberate conservative add-on**.
- The **industry video** and the **risk-week live session** are different objects. This live hour is formula + TVA + how to read for **technology** weeks.
- Chapter-per-week labels for 6, 7, 8 are **approximate**; **overlaps are expected**.

Exam lines

- Risk week mantra: identify, **measure**, then control — because you cannot control what you cannot measure.
- **Residual risk = LF × LM + measurement uncertainty.** Drop the old "minus % mitigated by current controls" when assessment already assumed those controls.
- LF = P(attack) × P(success); P(attack) from threat intel; P(success) from vulnerability / existing defense.
- LM = impact, with exposure as **percent of asset**.
- Add uncertainty to **step risk up** (worst case), because expert judgment is perceptual.
- TVA: threats down, assets across, vulnerability in the cell; sort; then success likelihood **per vulnerability**.
- For the coming **cybersecurity technologies** weeks, **read textbook chapters 6, 7 and 8 together** (chapter 5 is this risk week).

Lecture T25: Cybersecurity Technologies — Part 01

Learning focus

- Close the risk-management loop: identify → quantitative assessment → **management choice** among five strategies.
- Keep **defence** and **mitigation** from collapsing into each other.
- Justify a control with **ALE, SLE, ACS** (cost–benefit), then **monitor** because estimates are not actuals.
- See today's technology topic as **defence/protection**, complementary to last week's industry session (Mr. Sai).

Key terms

Term	Meaning in this lecture
Residual risk	Risk left after protection; detailed form includes minus existing protection + uncertainty
TVA	Asset–threat map that yields per-asset vulnerability and then risk
Defence	Invest to be ready **before / against** attack; cuts P(success) or exposure
Transfer	Pass operational cyber risk to vendor (outsource, cloud, managed services)
Managed services	Client **owns** assets; provider must keep them available / secure
Mitigation	**After** incident logic: spend to **cut impact** (contingency, hot site)
Acceptance	Informed choice to live with the number (Target comment; campuses)
Termination	Exit the asset or business when security spend cannot be justified
SLE	Single loss expectancy = loss magnitude = AV × exposure factor
ALE	SLE annualized by yearly frequency
ACS	Annualized cost of the safeguard
SP 830	NIST document-risk standard as **named in this lecture**

Distinctions

- Technology this week is **protection / defence**, not a full catalogue of every cyber tool.
- **Defence ≠ mitigation.** Firewall vs hot site. Mitigation **assumes the hit** and cuts **impact**. Using the words as synonyms is **incorrect**.
- Transfer ≠ "we no longer have a problem." **iPremier**. Client can still **own** assets under managed services.
- Cloud is **a** transfer option; transfer also includes classic outsourcing / managed services.
- Acceptance is not laziness if it is an **informed economic** choice; he still says campuses largely **accept**.
- Termination is a real fifth option, not a joke.
- **ALE post should be lower than ALE prior** (losses), even though you added ACS.
- A control with huge ACS can **fail CBA** even if it "improves security."

Exam lines

- Close risk with **five management options**; defence is only one, and it must pay for itself.
- TVA and per-asset residual risk go to management as a **comparative scale**.
- Transfer: outsourcing, cloud, managed services (ownership may stay); vendor must be competent (**iPremier**).
- Mitigation = contingency / hot site / impact reduction, **not** "another word for firewall."
- Acceptance (Target 70B vs 500M; academia) and termination (kill the unit) are rational when the economics say so.
- **SLE → ALE; compare ALE prior with ALE post + ACS.** Positive gain justifies the safeguard; then monitor.
- Next: what those defence and mitigation **technologies** actually are (managerial overview).

Lecture T26: Cybersecurity Technologies — Part 02

Learning focus

- Place access control, firewalls/DMZ, and cryptography as three **protection** families for CIA.
- Walk **identification → authentication → authorization → accountability** and the authentication factors actually named (password, passphrase, OTP, MFA, biometrics, voice/signature).
- Evaluate biometrics with **FAR, FRR, CER**, using the Andhra ration / worn-ridge case and the CAT-score analogy.
- State what a **firewall rule** does, what **trusted / untrusted / DMZ** mean here, and why cryptography **does not control access** but hides meaning.
- Contrast **symmetric vs asymmetric** key management, **digital signature** (reversed keys, non-repudiation), **digital certificates**, and the three cipher techniques (substitution, transposition, XOR).

Key terms

Term	Meaning in this lecture
Power asymmetry	Surveillance tech in the hands of government vs the governed (1984)
IAAA	Identify, authenticate, authorize, account
Passphrase	Phrase, not a word; harder to crack than a password
MFA	More than one factor, often a second **device** (OTP)
FAR / FRR / CER	False accept, false reject, crossover (device spec to check)
Trusted network	**Your** internal assets / data center
Untrusted network	Everything outside the organization
DMZ	Demilitarized zone: **replica** offered to outsiders via proxy

Term	Meaning in this lecture
Cryptography	Hide meaning **assuming** the channel is already accessed
End-to-end	Encrypted sender→receiver; intermediary (WhatsApp) cannot read
Symmetric	Same key both ways; **key distribution** is the hole
Asymmetric	Public locks, private opens (for confidentiality)
Digital signature	**Private** signs, **public** verifies — **non-repudiation**
Digital certificate	Third-party-managed site identity the browser checks
Caesar	Mono-alphabetic shift **p+k mod 26**
Transposition	Reorder bits in a block by a position key
XOR	Bitwise exclusive-or with a keystream

Distinctions

- This is **managerial awareness**, not crypto course design depth.
- 1984 is **surveillance / private space / power**, not a claim that 2020s India is Oceania.
- Identification is **issuing a unique mark**; authentication is **matching presentation to the store**.
- Password vs passphrase vs OTP vs biometric vs "what you produce" are different **factors**; MFA **combines** them, often across **devices**.
- FAR down **is not free** — FRR goes up (CAT 99.99). CER is the honest spec to read on a device.
- Worn labourers' fingerprints are a **technology** failure with **inclusion** consequences, not user stupidity; **five-finger** fusion was the local fix.
- Firewall **prevents access** by rule; cryptography **does not prevent access** — it prevents **reading**.
- Trusted = **ours**; untrusted = **not ours**. DMZ is a **replica / proxy**, not "the safe room where we stop monitoring" (contrast the industry guest's looser DMZ talk in T22).

Exam lines

- Protection stack taught today: **IAAA access control** (IDs, MFA, biometrics with CER), **firewall + DMZ/proxy**, **cryptography** (hide meaning on an untrusted path).
- 1984 and Minority Report frame surveillance power and biometric access.
- SBI MFA and Krishna-district five-finger rations are the Indian working examples; FAR/FRR trade-off is the CAT story.
- Symmetric = one key you cannot safely ship. Asymmetric = public lock / private unlock. Reverse the keys for **signatures and certificates** (Passport Seva, company filings, HTTPS padlock).
- Three primitive techniques: Caesar **p+k mod 26**, transposition of 8-bit blocks, XOR truth table. Standards come next class; active-defense presentation follows this hour.

Lecture T27: Foundations of Privacy — Part 01

Learning focus

- Finish the technology block: why encryption is "the heart of the matter," blockchain's CIA/hash story, and the **DES → 3DES / AES / RSA** ladder.
- Separate **"encryption was cracked"** from **backup / storage was in plaintext** (celebrity WhatsApp + NCB).
- State why privacy is **not an absolute right** (public interest, national security, Indian Telegraph Act 1885) and how **party-in-power vs opposition** flip the slogan.
- Use **Big Brother, Foucault, panopticon**, and the **IIT hostel CCD** fight as the surveillance teaching.
- Quote the classical definition: **"the right to be let alone"** (Warren & Brandeis, 1890, Kodak) and the Greek **polis / oikos** split; note reductionism vs coherentism.

Key terms

Term	Meaning in this lecture
Heart of the matter	Encryption — without it, no trustworthy e-commerce
DES	IBM 64-block / 56-bit; broken; led to RSA fame
AES	Widely used NIST/ISO standard; 128/192/256-bit keys
Immutability	Blockchain integrity via **hash** of each block
Backup gap	E2E in transit ≠ encryption of **cloud chat backup**
Public interest / national security	Media and state justifications that **qualify** privacy
Big Brother	Orwell's name for the power centre that watches
Panopticon	Observe all from one point; subject may not know
Indian Telegraph Act 1885	Legal tap of communications; not repealed
Right to be let alone	Warren & Brandeis 1890 — classical **privacy**
Autonomy	The freedom-stake that privacy is about
Polis / oikos	Aristotle's public vs private spaces
Reductionism vs coherentism	Privacy already inside "freedom" vs privacy as its own concept

Distinctions

- **Access control ≠ encryption.** Encryption is what you do **after** someone may still see the bits.
- He has **not** seen a standard-ciphertext broken in the wild; **do not** use the celebrity chats as "WhatsApp crypto failed."
- Backup / Drive / credentials are a **different surface** from E2E.
- Getting the chats for **investigation** is not the same as **TV broadcasting** them.

- Privacy is **not absolute**; national security is the court's cave-in; **politics flips** the slogan.
- Security cameras can be **welfare** and **abuse**; panopticon is the name of one-point watch.
- **Corridor vs room** is the live privacy boundary on campus.
- Collectivist postcard culture ≠ "Indians never had privacy"; **consciousness** of the individual right is late and partly **Western-framed**.

Exam lines

- Close tech: encryption underpins e-commerce; DES died to RSA; AES/RSA key lengths make brute force "virtual" fantasy; blockchain = encrypt + private-key non-repudiation + hash immutability.
- Open privacy with a case where **crypto worked** and **backup + media** did not.
- Big Brother / Foucault / Telegraph Act 1885 / panopticon / IIT cameras: **power asymmetry**, informed surveillance, public vs private **place**.
- Warren & Brandeis 1890, Kodak, **right to be let alone**, Pitt's hut, Aristotle's two spaces, reductionism vs coherentism.
- Next lectures move from this general privacy to **information privacy** (T28) and the We Googled You case (T29).

Lecture T28: Foundations of Privacy — Part 02

Learning focus

- Place economic and feminist **views of privacy** beside the "let alone" tradition.
- Quote **Alan Westin's** definition and use it to split **privacy** from **information privacy**.
- List the **Fair Information Practice Principles (FIPP / FIPPs)** as taught from the 1973 US advisory report — including Aadhaar-style **collect only what you need**.
- Name the three entities **data subject / controller / processor** (and India's principal / fiduciary / processor).
- Measure **concern for information privacy (CFIP)** on four dimensions: collection, unauthorized access, errors, secondary use.

Key terms

Term	Meaning in this lecture
Posner 1975	Privacy matters to economists when it has **economic consequence**
Westin	Control over **when, how, to what extent** information is communicated
Information privacy	Decide what you share; not the same as physical "let alone"
FIPP / FIPPs	1973 Fair Information Practice Principles — template for later law
Secret systems	Forbidden: the **existence** of the file must not be hidden

Term	Meaning in this lecture
Purpose / consent	No **secondary use** without the person's consent
Data subject	The individual (India draft: **principal**)
Data controller	Collects and **decides** (India draft: **fiduciary**)
Data processor	Third party (or same org) that **processes**
CFIP	Measurable **concern**: collection, unauthorized access, errors, secondary use
Profiling	Credit bureaus / merchants building a picture of you
Retire vs delete	Platforms may stop showing you and still **keep** the record

Distinctions

- **Privacy** (let alone, body and home) is not **information privacy** (control of **disclosure**).
- Economists ignore privacy **until liability / theft shows up in money**.
- A locked family door can be **protection** or a **cover for abuse** — feminist critique of "private."
- FIPP-1 is about the **existence** of the system, not only the accuracy of rows.
- Shaadi-style **perpetual license** is exactly the **secondary-use** problem FIPP-3 targets — **read the policy**.
- **Security spend** is not a separate "IT hobby": under FIPP it is a **privacy duty** of the collector; breach = principle broken.
- Controller **decides**; processor **handles**; they may be the same legal person.
- India's dropped PDP bill **renamed** the roles (principal / fiduciary) without throwing the triad away.

Exam lines

- Westin: information privacy = **control over communication of information about you**.
- 1973 FIPPs (no secret files, access, purpose/consent, correction, minimization, collector security) underlie GDPR-style law.
- Subject / controller / processor (principal / fiduciary / processor).
- CFIP = collection + unauthorized access + errors + secondary use (GATE DOB).
- Orgs worry because of **liability**; people worry because of **harm and embarrassment**; credit bureaus show the profiling machine; **We Googled You** is next.

Lecture T29: Foundations of Privacy — Part 03

Learning focus

- Reconstruct the **Hathaway Jones / Mimi Brewster** case as the lecture actually argued it (facts, stakeholders, two exam questions).
- Separate **"it was public, so not a privacy violation"** from **"on what ground may you reject, and must you disclose the Google search?"**

- List the **policy layers** the student team mapped (FCRA, GDPR consent-to-check, EEOC, NLRA, HIPAA) and the screening hygiene they proposed.
- Hear the instructor's pushback: **authoritarian China**, Tiananmen, **organizational legitimacy**, inner HR–CEO politics, and why "keep her in the US" may **defeat the hire**.
- Translate the case into **personal** practice: do not vanish online; **Google yourself**; professional vs private accounts.

Key terms

Term	Meaning in this lecture
Invasive background check	More personal data than the job needs (status, credit, health, race)
We Googled You	HBR-style case: luxury firm, China expansion, Google dirt on the hire
Public domain argument	If press already published it, reading it is not secret surveillance — **but rejection reason still regulated**
Screening policy	Written, layered, job-relevant, transparent — so HR is not improvising with lawyers
GDPR (as applied here)	**Awareness / explicit consent** before checking **EU** people
EEOC / NLRA / HIPAA / FCRA	Anti-discrimination, protected concerted activity, health data, credit/consumer data
Legitimacy	Firm's ability to operate in a host polity (China) without political blowback
Digital vanishing	Empty search can look like **hiding**; worse than a cleaned professional page
Google yourself	Recurring self-audit (+ alerts) of what employers will see

Distinctions

- **Public ≠ anything-goes rejection.** Reading page nine may not violate secrecy; **rejecting for ideology, race, health, or union-like protest** can still be illegal or illegitimate.
- Telling Mimi "we Googled you" is a **separate** legal/PR risk from doing the search.
- Confronting her does **not** dissolve the **China** problem; the activism **stays Googleable**.
- Parking her in the US **may save face and lose the reason she was uniquely valuable**.
- **Authoritarian** host vs **democratic labour statutes** (NLRA) — the slide stack is Western; **Tiananmen** is the instructor's correction.
- Inner-circle **politics** can dress up as "privacy diligence."
- Erasing your whole footprint is not "more private" to employers — it reads as **concealment**.
- Fake internet content exists — **hear the candidate** before treating Google as a court.

Exam lines

- We Googled You: Fred wants Mimi for China; Virginia's nine-page search finds old **anti-WTO** and **anti-China-government** protests; lawyers enter.
- Privacy analysis: **public records / press** vs **how far** and **why you use** them; write a **layered screening policy**; GDPR-style **notice**; keep health and protected classes out.
- Business analysis: hire → China legitimacy and competitor attacks; don't hire → **discrimination** suit and she goes to a rival.
- Instructor's exam-level complexity: **credentials vs authoritarian politics vs org politics**; via media (confront, probation) without pretending the host state is a liberal campus.
- For you as a candidate: **Google yourself**, keep a **professional** public trail, do not assume delete = gone.

Contents

Volume 05 — Regulation, Economics, Strategy, Capstone **1**
Lecture T30: Privacy Regulation — Part 01 1
Lecture T31: Privacy Regulation — Part 02 3
Lecture T32: Privacy Regulation — Part 03 5
Lecture T33: GDPR — Part 02 6
Lecture T34: GDPR — Part 03 8
Lecture T35: Privacy: The Indian Way — Part 01 9
Lecture T36: Privacy: The Indian Way — Part 02 11
Lecture T37: Privacy: The Indian Way — Part 03 12
Lecture T38: GDPR — Part 01 14
Lecture T39: Information Privacy — Economics and Strategy — Part 01 15
Lecture T40: Information Privacy — Economics and Strategy — Part 02 16
Lecture T41: Information Privacy — Economics and Strategy — Part 03 18
Lecture T42: Privacy — Strategy and Safety — Part 01 19
Lecture T43: Privacy — Strategy and Safety — Part 02 20
Lecture T44: Privacy — Strategy and Safety — Part 03 21
Lecture T45: Cyber Security and Privacy — Capstone Discussion A 23
Lecture T46: Cyber Security and Privacy — Capstone Discussion B 24

Volume 05 — Regulation, Economics, Strategy, Capstone

Cyber Security and Privacy · NPTEL 106106248 · Prof. Saji K. Mathew **notes-3** — concept exam notes (definitions & what things do). Breadth over lab depth.

Lecture T30: Privacy Regulation — Part 01

Learning focus

- Explain why privacy concern, once it is collective, becomes a regulatory problem for the state.
- Show how platform **lock-in**, unread privacy clauses, and immediate gratification produce one-sided data exchanges.
- Define the **privacy paradox** as the clash between wanting a personalised experience and wanting privacy.
- Distinguish **right to privacy** from **right to anonymity**, using Derek Smith / ChoicePoint.
- Separate **personal data**, **personally identifiable information (PII)**, and **quasi-identifiers**.

Key terms

Term	Meaning in this lecture
Lock-in	Enter a product/service and cannot leave; switching cost prohibits exit. Built into platform strategy.
Switching cost	Cost of moving to another product or service; when high, you stay.
Immediate gratification	Economist's name for rushing to the service and clicking agree without reading.
Non-monetary exchange	You pay with data, not money; still an exchange (no free lunch).
Right to be let alone	Classic privacy formula — which most people do not actually want, because they want to socialise.
Selective disclosure	Choosing what a profile shows in order to make an impression.
Privacy paradox	Wanting both the best personalised/free service and privacy; the two conflict.
Right to privacy vs anonymity	Privacy is not invisibility; Smith: you cannot have a right to anonymity in this society.
Personal data	Any data that is yours and related to you.
PII / identifiable data	Attributes that uniquely or partly identify you.
Quasi-identifier	Not unique alone (e.g. name); combining several can identify.

Frameworks / formulas

- **Regulation warrant:** individual concern → collective/pervasive breach → citizen-data held by industry → government welfare role → regulate.
- **Unfair consent stack:** lock-in + unread legal text + immediate gratification + one-sided click-wrap → need for regulation (GDPR later).
- **PII construction:** quasi-identifiers + linking ≈ identification.

Distinctions

- Cybersecurity and information privacy share concepts, but privacy concern is its own domain — how well you address it is the privacy problem.
- Lock-in is not mere preference; it is a designed platform strategy (Hotel California).
- "Free" digital service is not free; it is a non-monetary data exchange, which is why court challenges fail once you clicked agree.
- Privacy agreements are one-sided **by design**; fairness, not just individual carelessness, is the regulatory issue.
- Very few people want to be let alone; the social need and selective disclosure are why platforms harvest so much.
- You raise privacy concerns when the **trade of data affects you**, not when you take the discount — that is the paradox.
- **Right to privacy ≠ right to anonymity.** You cannot be anonymous on the planet and still claim the privileges of a state.
- Name is personal data and a quasi-identifier; it is not, by itself, a unique identifier.

Exam lines

- Regulation is needed because breaches are pervasive, organisations store citizen data, and government's job is welfare.
- Platforms lock users in; privacy policies take ~76 working days to understand; click-wrap is not fair play.
- Privacy paradox: personalised experience vs privacy; both are wanted, both cannot be fully had.
- Mandatory state disclosure is the harder case of the same tension.
- ChoicePoint/Smith: privacy yes, anonymity no.
- Personal data vs PII vs quasi-identifiers; linking can finish the identification GDPR will later regulate.

Lecture T31: Privacy Regulation — Part 02

Learning focus

- Separate **anonymity, secrecy, confidentiality, transparency, privacy, and security**, which the instructor says are often confused.
- Place total anonymity, **pseudo-anonymity**, and identifiability on one scale, including Aadhaar's pseudo identifier.
- Apply three privacy-preserving data-mining techniques: **randomization, anonymization, encryption**.
- State **k-anonymity** (Sweeney), and distinguish **suppression** from **generalization**.
- Use the **risk–utility (R–U) map** as the analytics trade-off that regulation must govern.
- Contrast US sectoral law, FIPPs/OECD principles, the EU **directive**, and the 2018 EU **regulation**.

Key terms

Term	Meaning in this lecture
Anonymity	Ability to conceal identity; share facts that cannot be accurately linked to you.
Pseudo-anonymity	Substitute ID (Aadhaar-issued) that an agency can map back; business cannot. Not pure anonymity.
Secrecy	Intentional concealment; may mislead; low volume and low accuracy.
Confidentiality	Limited sharing; when shared, complete and identified. Organisational word.
Privacy	Typically the individual-level counterpart of confidentiality.
Transparency	High accuracy and high volume shared (public institutions).
Randomization	Share $x_i + e_i$, not x_i; processor sees noise / distribution, not exact values.
k-anonymity	Every quasi-identifier combination matches at least k people.
Suppression	Remove a column entirely.

Term	Meaning in this lecture
Generalization	Coarsen (year not full DOB; truncated zip; last-4 of Aadhaar).
Linking	Re-identify anonymized records by joining more data.
R–U map	Trade-off of disclosure **risk** vs data **utility**.
Directive vs regulation	EU pre-2018 D = not enforceable as such; 2018 R = law.
FIPPs	US Fair Information Practice Principles — principles, not a statute.

Frameworks / formulas

- **Randomization:** processor receives $x_i + e_i$, e_i random noise from some distribution.
- **k-anonymity:** each released quasi-identifier tuple is indistinctly matched to ≥ k individuals; k is the extent of anonymization.
- **2×2:** accuracy × amount shared → secrecy / anonymity / confidentiality / transparency.
- **R–U:** more disclosure → more risk and more utility; regulation is choosing the operating point for a country.

Distinctions

- Pseudo-anonymity is **not** pure anonymity: Aadhaar (or another agency) can reconstruct.
- Grade / a fact-table **measure** is not PII; name, roll, email are.
- Confidentiality ≠ privacy (organisation vs individual, in the literature used here).
- Secrecy is not anonymity: secrecy can be inaccurate and misleading; anonymity can share a lot of true facts without a link.
- Incognito hides the **local machine**, not the service provider.
- Suppression is dropping a column; showing last-4 digits is **generalization**.
- FIPPs and the old EU instrument are **not** regulations; HIPAA is domain-specific; the US has **no omnibus** personal-data law; GDPR is the broad template.

Exam lines

- Four-quadrant map is the clean way to keep secrecy, anonymity, confidentiality, and transparency apart.
- PPDM: randomize, anonymize, or encrypt before a processor sees data.
- k-anonymity + suppression + generalization; linking is why they are not enough.
- Last-4 Aadhaar is generalization.
- R–U: personalisation needs identity; privacy needs blur; regulation governs the middle.
- 2018: EU directive becomes regulation. US remains sectoral and state-wise — which the Equifax case will show as a limitation.

Lecture T32: Privacy Regulation — Part 03

Learning focus

- Reconstruct the **Equifax 2017** breach: business model, unpatched **Apache Struts**, stolen PII, delayed disclosure.
- List privacy harms of a credit-bureau leak (identity theft, loan fraud, targeting, Aadhaar-scale analog in India).
- Separate **technical** failures (patch, SSL, logs, ACIS) from **governance** failures (CLO over CSO, board silence on public cyber ratings).
- Follow the class debate: **negligence vs unlucky**, then the instructor's question — where is the **major** problem?
- State why **breach-notification timelines** (US patchwork vs later GDPR **72 hours**) are the regulatory lesson.

Key terms

Term	Meaning in this lecture
GTVM / VAT / Countermeasures	Equifax threat-tracking, scanning, and blocking functions that still failed.
Apache Struts	Open-source Java web framework; public exploit was the entry.
Web shell / backdoor	~30 persistence paths Equifax did not see.
ACIS	Old (class: 1970s) control that blocked one IP and could not see the rest.
File-integrity monitoring	Missing control: scan for unauthorised access / suspicious events.
Credit freeze	Lock the file so new credit cannot be opened — Equifax charged for it after the breach.
Clawback	Recovering executive pay after failure.
Breach notification	Duty to tell people and regulators in a fixed time so they can act.
CCC / FICO cyber	Public cyber ratings the board could have interrogated and did not.

Frameworks / formulas

- **Two-chain model:** security says what; technology deploys; CEO must actually integrate them.
- **Notification comparison taught here:** US mix of 45 days / none → proposed **30-day** consumer notice; NY **72 hours** to regulators; GDPR (preview) **72 hours**.
- **Governance test:** did the board have independent, public evidence (audit, MSCI, CERT) and fail to ask?

Distinctions

- Investment and a CSO on the org chart ≠ security. Equifax spent >1% of revenue and still failed.
- **Post-hoc** blame is easy; still, the **major** documented failure is **corporate governance**, not "Equifax was unlucky."
- Board fault is not micromanaging patches; it is **not reacting to information it had** (2015 audit, public CCC).
- CLO presenting cyber without cyber competence is a structural, not a personality, problem.
- Cybersecurity at this scale is **enterprise risk / governance**, not only IT.
- Delayed disclosure is not a PR issue only: without a legal clock, **the individual cannot freeze credit**. That is why regulation must specify days.
- Equifax is a **data business** and a **high-value target**; "attacks happen every day" is not an excuse.

Exam lines

- Vector: unpatched Apache Struts after a public CERT alert; persistence via web shells; expired SSL; 8,500 leftover vulns.
- 143 million Americans (~half of adults); SSN-level PII.
- Disclosure ~six weeks after discovery; no US-wide rule.
- Root cause the class is meant to leave with: **governance** (board + split IT/security under a non-expert CLO) plus **no mandatory notification**.
- Bridge to Europe: GDPR puts the 72-hour clock and processor/controller accountability into law.

Lecture T33: GDPR — Part 02

Learning focus

- Attribute GDPR's foundation, as the lecture does, to **Ann Cavoukian** and her **privacy by design / by default** line.
- Turn GDPR into organisational work: **records, DPIA, 72-hour notice, DPO, vendor contracts, third-country safeguards**.
- Explain why **COVID / hybrid work** is used to account for the surge in fines.
- State the lecture's "way forward": privacy as **new normal** and **brand differentiator** (~120 country laws; 82% see certifications as a buying factor).
- Take the implementation Q&A seriously: culture, manufacturing capability, import leverage, and **aware people** plug loopholes more than text does.

Key terms

Term	Meaning in this lecture
Privacy by design	Embed protection at conceptual/design stage, not after go-live.

Term	Meaning in this lecture
Privacy by default	Settings protect the user without extra action; full functionality, not a trade-off.
Positive-sum	Cavoukian: not “some privacy vs some function.”
SCC / BCR	Standard contractual clauses / binding corporate rules when the destination lacks adequacy.
Demonstrate adherence	Accountability is not only doing; it is showing (certification).
SASE / hybrid	Remote work makes GDPR compliance “hectic”; security protocols must follow the user.
Privacy as differentiator	Certification / shield as a **buying factor** (82%).

Frameworks / formulas

- **Cavoukian seven** (as taught): full functionality, end-to-end, transparency, user-centricity, proactive, embedded design, default.
- **Post-breach triad:** 72h to authority + notify individuals + technical/organisational detect-report-investigate.
- **Third-country fork:** adequacy-like protection **or** SCCs/BCRs/contracts.
- **Fine trajectory they cited:** min €2,000; 306 (2020) → 429 (2021); seven-fold money, blamed on COVID attack surface.

Distinctions

- Privacy in the product is **not an afterthought** and not a zero-sum against functionality.
- 72 hours is not only “tell the regulator”; **tell the person**.
- Strength of controls **scales with sensitivity** — medical/legal data is not a cookie banner.
- Processors outside the EU (India included) are in via **contract**, not via geography.
- More fines in 2020–21 are taught as **WFH unpreparedness**, not only “evil Big Tech.”
- Exporting to the EU buys **leverage for EU rules**; importing does not. India’s 5% idea does not erase that.
- Implementation gaps close with **educated users**, not only with stricter text.

Exam lines

- Lecture founder figure: Cavoukian; slogans: no borders; by design; by default; positive-sum.
- Operations: processing records, breach logs, DPIA on new processing, DPO, 72h + individual notice, SCCs/BCRs for India-like destinations.
- Privacy is becoming a market factor (82%) and a global template (~120 laws).
- The hard part, in Q&A, is **implementation** given culture, industrial capability, and awareness — not drafting another article.

Lecture T34: GDPR — Part 03

Learning focus

- Argue both sides: GDPR as **accountability** (Equifax lesson) vs GDPR as a **constraint on data-driven business models**.
- Explain **privacy by default as a nudge** (default radio button = I disagree).
- Show why **cookie banners** may not produce real consent (gratification, no time to read).
- Map **third countries** and the lecture's **14 "secure" / expressly permitted** countries — **USA and India not on the list**.
- Apply GDPR to **IIT Madras**: EU exchange and joint-degree data, MOUs without privacy clauses, photo consent at Passau.

Key terms

Term	Meaning in this lecture
Downside of GDPR	May stifle ad-funded, data-native business models.
Accountability	Equifax hole GDPR fills: who is liable, what penalty, when to report — collectors **and** processors.
Nudge	Default option steers choice; privacy-by-default = default **disagree**.
Cookie consent	Post-2018 banners; lecture conclusion: does **not practically work** as informed consent.
Harmonisation	GDPR is a regulation, uniform for members; unlike DPD.
Third country	Non-EU destination; India is one.
Expressly permitted / 14	Countries treated as safe for free transfer; **not** US, **not** India.
MOU	The contract through which a university relationship should (but often does not) carry GDPR duties.

Frameworks / formulas

- **Balance:** accountability and no-abuse **versus** not killing data businesses; privacy is not absolute.
- **Default test:** radio button on signup = disagree if you are serious about privacy-by-default.
- **Transfer test:** on the 14-list → express permission; else **specific contracts**.
- **University test:** do we store EU persons' data? Then GDPR awareness is not optional, complaint or no complaint.

Distinctions

- "Do business without personal data" is too simple; **stricter law does stifle** some models — and **no law** enables Equifax-style unaccountability and platform misuse.
- Privacy is **not absolute**; people will share; they refuse **abuse**.
- Privacy by default is a **nudge**, not a moral sermon.

- Cookie banners are **compliance theatre** if nobody can read them — same immediate-gratification problem as T30's 76-day privacy policy.
- GDPR is **harmonised for members**; remaining differences (Ireland/Netherlands) are not a licence to shop for a blind regulator.
- Adequacy is **political/legal**, not "USA is advanced so it must be on the list."
- IIT is not outside GDPR because it is Indian; **EU student data** is enough. Informal Indian breach culture is **not** the European standard (Passau photos).
- Wanting Indian law to be "very strict" and then complaining about lost opportunities is the same flip the next India lectures will hit.

Exam lines

- GDPR's teeth (fines, 72h, processor liability) are the point of Equifax; the cost is pressure on ad-tech models.
- Default-disagree and privacy-by-design are the innovative ideas; banners mostly fail the human-time test.
- India and the US are **third countries**, not on the 14; contracts must carry GDPR.
- IIT Madras already processes EU data (exchanges, joint degrees); MOUs and photo practice are the awareness gap.
- Next: Indian constitutional privacy, Puttaswamy, Aadhaar, DPDP.

Lecture T35: Privacy: The Indian Way — Part 01

Learning focus

- Read **Article 21** as personal liberty **with** the clause "except according to procedure established by law."
- Place the **Indian Telegraph Act 1885** (and **1972** amendment) beside that liberty: the state has interceptive rights.
- Name **Justice K.S. Puttaswamy** as the lecture's "father of data privacy in India" and state the **24 August 2017** holding.
- Apply the **threefold test** (legality, need / legitimate state aim, proportionality).
- Trace **Srikrishna → PDP bill dropped → DPDP 22 bill**, in parallel with GDPR 2018.
- Hold both lines: privacy is a **fundamental right** and **not absolute**; the state has **no absolute power to snoop**.

Key terms

Term	Meaning in this lecture
Article 21	Life and personal liberty except by procedure established by law.
Indian Telegraph Act 1885	Colonial intercept statute; still the legal spine of tapping.
1972 amendment	Emergency-period expansion of wiretap, including opposition.

Term	Meaning in this lecture
Data fiduciary (here)	Government as custodian of 1.3B Aadhaar records.
K.S. Puttaswamy	2012 PIL; “father of data privacy in India.”
Inner sphere / autonomy	Core of the 24 Aug 2017 holding; state **and** non-state actors.
Srikrishna Commission	Expert draft of PDP after consultations, GDPR-aware.
PDP	2018 Personal Data Protection bill; government altered; Parliament stalled; **dropped**.
DPDP 22	Digital Personal Data Protection bill that replaced it (still a bill in this lecture).
Threefold test	Legality, legitimate aim, proportionality.

Frameworks / formulas

- **Art. 21 structure:** liberty **+** “except according to procedure established by law.”
- **Puttaswamy formula:** fundamental right protecting inner sphere from state and non-state interference → autonomous life choices.
- **Snoop test:** no intercept without legality + need + proportional collection.
- **Two parallel lines:** welfare / unique ID **vs** autonomy to refuse biometrics → **regulation**.

Distinctions

- Do not quote Article 21 without the **exception**.
- Telegraph Act and Article 21 **coexist**; conflict is structural, not an accident.
- He **mis-speaks 2018**, then pins the judgment at **24 August 2017** — use the corrected date.
- Puttaswamy is not a slogan; it is a **writ** the Court had to decide.
- Government, not Facebook, is India’s **largest** personal-data controller.
- Mandatory Aadhaar-for-benefits vs fundamental privacy is a **grey area**, not a one-line win for either side.
- End use (fraud reduction in Assam) is relevant **and** there is **no guarantee** against compromise — hence a statute.
- Majority-benefit vs elite-privacy is the **privacy paradox** again, not proof that rights do not matter.

Exam lines

- 1885 intercept + 1950 Art. 21 + 1972 tap + 2012 PIL + **24 Aug 2017** fundamental right + 2018 PDP + dropped + **DPDP 22**.
- Father of Indian data privacy in this course: **Puttaswamy**.
- Three tests for invasion; ~10 agencies still sit on the Telegraph Act.
- Aadhaar made the state the main fiduciary; that is why privacy had to be constitutionalised.
- Next lecture: Aadhaar Act, Nilekani, architecture, weak links.

Lecture T36: Privacy: The Indian Way — Part 02

Learning focus

- Show that Aadhaar collection is **"according to procedure established by law"** because there was an **Aadhaar Act** first.
- Explain the **welfare / anti-leakage** rationale: multiple identities, **₹1 → 70 paise**, information asymmetry (IRCTC).
- Describe Aadhaar as a **12-digit platform** run by **UIDAI**, designed by **Nandan Nilekani**, with a **minimalist** collection claim.
- Map **CIDR / ASA / AUA / device / user** and the **yes/no** authentication design.
- Locate **weak links**: enrolment vendors, disclosed Aadhaar numbers, **linking**, the "10-foot wall" vs Keshav's open back door.
- Note Supreme Court **limits on mandatory Aadhaar** and the still-open **DPDP** debate on how safe the database is.

Key terms

Term	Meaning in this lecture
UIDAI	Statutory authority for Aadhaar collection and database.
Aadhaar Act	The "procedure established by law" that makes collection legal.
Leakage	Share of welfare rupee that does not reach the target (here 30 paise).
Platform (Aadhaar)	Base database on which many participant-types connect and build.
Minimalist collection	Only basic identification data, not full demographics — Nilekani claim.
CIDR	Core identities repository behind the data-centre wall.
ASA	Enlisted technical path to CIDR (BSNL, NIC, telcos).
AUA	Face-to-face service agency (bank, telco, passport).
Yes/no authentication	AUA does not receive the biometric payload; only match result.
Weakest link	Cartoon/chain: not the wall; vendors, numbers, other websites.
Pseudo ID / VID idea	Substitute number so the raw Aadhaar is not left with every AUA.

Frameworks / formulas

- **Art. 21 applied:** Aadhaar Act ⇒ legality of collection is settled; **use, mandate, and security** remain open.
- **Leakage identity:** multiple IDs ⇒ ₹1 welfare → 70 paise; unique biometric ID is the state's efficiency answer.
- **Layered access:** User → device → AUA → ASA → CIDR; compare to T31's processor chain.
- **Weak-link audit:** core encryption ≠ no leak if collection vendors and downstream number-holders are open.

Distinctions

- **Legal** collection (Aadhaar Act) does not answer **mandatory use** or **security of the chain**.
- Party politics is the wrong frame; **every** government digitised; Nilekani had to work **across** parties.
- Aadhaar as **platform** is a design claim (orchestration), not "just a government file."
- **Minimal data at collection** is the official theory; **thousands of vendors** are the practice.
- Supreme Court: Aadhaar not mandatory for all **fundamental** services; **SIM** still requires it in this lecture's India.
- Gulshan Rai's wall is **physical security rhetoric**; Keshav's back door is the analytical point.
- He will **not** assert a proven leak **from CIDR**; he **will** assert vendor firing and public web dumps of numbers collected elsewhere.
- Authentication **yes/no** protects biometrics in transit **and** still leaves the **12-digit ID** and **linking** problem — same quasi-identifier logic as T31.

Exam lines

- Aadhaar is lawful (the Act), welfare-rational (70 paise, multiple IDs), and a Nilekani **platform** with a 12-digit unique key.
- Architecture: CIDR behind ASA/AUA; telcos are both.
- Risk is the **chain**: enrolment vendors (~1,000 fired), Aadhaar numbers sitting with AUAs and other websites, linking/profiling; pseudo-ID is the taught mitigation.
- SC cabined mandatory use; SIM/banking still pull the ID.
- "100% secure / 10-foot wall" fails the weakest-link test the cartoon and the IIT Delhi paper (in Srikrishna) were assigned to teach.

Lecture T37: Privacy: The Indian Way — Part 03

Learning focus

- State the government's terms of reference for the Justice Srikrishna Commission and why they put the data economy first.
- Map the three data actors in PDP/DPDP against GDPR language.
- Compare the Personal Data Protection (PDP) draft with the Digital Personal Data Protection (DPDP) bill as taught in class.
- Argue both sides of data localisation, including cost, jurisdiction, jobs, and corporate power.

Key terms

Term	Meaning in this lecture
Data principal	Individual whose data is collected (GDPR data subject)
Data fiduciary	Controller: collects, stores, decides sharing and processing; "guardian" of data

Term	Meaning in this lecture
Data processor	Party that only processes data shared by the fiduciary
SPD	Sensitive personal data — health, financial, passwords, matrimonial/preference data
CPD	Critical personal data — undefined in PDP; government could designate it; meant for in-country storage
Data localisation / residency / sovereignty	Citizens' data stored inside the country so Indian law still applies
Right to erasure	DPDP substitute for PDP's right to be forgotten; may not cover onward sharing
Rule-making power	Central government can make rules under ~14 of DPDP's 22 clauses
Conflict of interest	Government as large fiduciary **and** rule-maker

Distinctions

- Unlocking the **data economy** is first in the TOR; privacy is to be upheld **without destroying data businesses**.
- **Fiduciary ≠ processor.** Analytics vendors process; they do not decide collection and sharing.
- **Right to be forgotten ≠ right to erasure** if sharing among entities is the issue.
- **Legal jurisdiction follows the data.** Once data is in country X, Indian PDP/DPDP cannot simply follow it.
- Localisation is not only a privacy slogan; it is a fight among **state control, corporate cost, and jobs**. DPDP's dilution is taught as **corporate interest**, not as simple "privacy loss."
- Government need for access is **legitimate**; combining **fiduciary + regulator** is the conflict, not the need itself.
- Srikrishna's "Orwellian" remark is about **the amended bill**, not the original draft, and is not to be reduced to party politics.

Exam lines

- TOR: unlock data economy **and** protect citizen data — economy named first.
- PDP 2019: Cabinet bill with extra **government access** powers; Srikrishna disowns it; bill dropped.
- DPDP 2022: 6 chapters / 24 pages vs PDP 14 / 56; PII only; 22 clauses; government rules in ~14; penalty cap **₹500 crore**; principals can be fined for false claims.
- Actors: principal, fiduciary (Aadhaar), processor; GDPR-style contracts and processor liability.
- PDP three-tier data (personal / SPD / CPD) and strict localisation of SPD+CPD **removed** in DPDP.
- Localisation plus/minus: jurisdiction and Indian analytics vs DC cost, scale, few jobs, corporate non-competitiveness.

- Next theme already announced: if privacy law makes data as expensive as scarce oil, data businesses die.

Lecture T38: GDPR — Part 01

Learning focus

- Restate the **need for regulation** as a fair balance among data collectors, processors, and individuals.
- Contrast US **sectoral / toothless** law (Equifax notification gap, no set penalty) with the EU move from **1995 DPD** to **GDPR 2018**.
- Define GDPR **personal data** (direct and in-conjunction identifiers).
- List the **six principles**, **six legal bases**, **controller / processor / DPO** roles, and **data-subject rights**.
- State the fine: **€20 million or 4% of global annual revenue, whichever is higher**, and 72-hour breach notice.

Key terms

Term	Meaning in this lecture
DPD (1995)	Directive: member states write their own laws; not uniform.
GDPR	Regulation: law, enforced 2018 (adopted 2016).
Personal data	Identifies on its own **or in conjunction** (IP, device ID, geo, biometrics).
Controller	Decides purposes and means.
Processor	Processes on behalf; now jointly liable; needs a contract.
Pseudonymization	Replace original with artificial data.
DPO	Mandatory central contact for GDPR compliance.
DPIA	Project-specific high-risk impact assessment; privacy by design.
72 hours	Uniform breach notification window under GDPR.
4% / €20M	Ceiling on administrative fine, higher of the two.

Frameworks / formulas

- **Scope test:** EU establishment **or** processing of people residing in the EU.
- **Lawful processing:** one of six bases; not “because we want the data.”
- **Accountability pair:** controller **and** processor; DPO; DPIA for high risk; 72h notice; 4% / €20M.

Exam lines

- GDPR applies to anyone processing EU residents’ data, not only EU companies.
- Six principles (lawfulness/fairness/transparency through CIA) and six legal bases (consent through legitimate interest).
- Roles: subject, controller, processor, DPO; mermaid above.
- Rights: access, know, rectify, erase, restrict, port, object.

- Uniform 72-hour breach notice and 4% / €20M fines are the “teeth” the US cases lacked.

Lecture T39: Information Privacy — Economics and Strategy — Part 01

Learning focus

- Explain why privacy must have an **economic value** if businesses are to spend on it.
- Show why cloud/controller–processor **contracts** still use thumb rules instead of a valuation model.
- Run the Gmail classroom experiment as **WTP vs WTA** and name that gap the **privacy paradox**.
- Apply **loss aversion**, **endowment effect**, and **stated vs revealed preference** to privacy pricing.

Key terms

Term	Meaning in this lecture
Valuation of privacy	Assigning economic value to PII databases so contracts can set breach penalties
Thumb rule	Industry substitute for a model — here **5% of contract value**
WTP	Willingness to pay to **protect** privacy (tends low)
WTA	Willingness to accept money to **give up** privacy (tends high)
Privacy paradox	Advocate privacy in talk; cheap to buy protection, expensive to sell it
Loss aversion	Pain of loss weighted above equivalent gain; prospect theory
Endowment effect	Extra value because the thing is already yours; parting pain
Privacy calculus	Mental trade-off when deciding about privacy
Stated preference	What you say in a survey
Revealed preference	What you do in a game or in the market
Contingent valuation	Economist’s tool using those two preference types

Distinctions

- Privacy without **economic or strategic** implication is not a business topic.
- **Regulation requires contracts**; contracts require a number; **research has not supplied a stable model**.
- **5% of contract value is not valuation** — it is a thumb rule that can under- or over-shoot real loss.
- **WTA is not WTP.** The paradox is that gap, not that people “don’t care.”
- This is **not** neoclassical rational man; it is **behavioural economics** (Kahneman): loss aversion and endowment.

- **Stated 5/5 on a survey is not revealed behaviour.** Contingent valuation exists because those two split.
- Privacy value is **context specific**; there is no all-weather unit price for a database.

Exam lines

- Why value privacy: controller–processor contracts, cloud, GDPR-style shared breach liability.
- Industry: **5% of contract value**; DPDP cap ₹500 crore as a guideline number.
- Gmail quiz: low pay-to-block-scan, high accept-to-allow-human-read → **privacy paradox**.
- Explain with **loss aversion** (pain, embarrassment, certainty over gambles) and **endowment** (trophy / 15-year inbox).
- Stated vs revealed preference; contingent valuation.
- Next case moves from the individual to **organisations trading private data**.

Lecture T40: Information Privacy — Economics and Strategy — Part 02

Learning focus

- Reconstruct the HBR discussion case The Dark Side of Custom Analytics (Davenport and Harris) as presented in class.
- Judge the proposed grocery–insurer data deal from **ShopSense** and **IFA** sides: money, law, trust, strategy.
- Separate **legal consent** in a loyalty programme from **ethical** use of grocery data to set health premiums.
- Contrast **Progressive**'s transparent driving logger with covert supermarket-to-insurer sharing.

Key terms

Term	Meaning in this lecture
Loyalty programme	Legal hook: customer consents to analytics in exchange for discounts
Scanner information	Item-level purchase data already traded without shopper knowledge
Personalised insurance	Premium/product fitted to **individual** behaviour (driving or grocery)
Legal vs ethical	No prohibiting statute ≠ no trust/relationship harm
Battered customer syndrome	After profiling, service concentrates on the top slice; the rest leave
Pilot / evidence-based deal	Trans-fat–claims correlation shown **before** the contract

Term	Meaning in this lecture
Exclusive data rights	IFA's hoped-for hurdle against rival insurers

Frameworks / formulas

	ShopSense	IFA
Gain	~$1B; already-paid analytics asset	Risk insight; new product; exclusive moat
Legal story	Loyalty T&Cs; state law silent	Insurers are expected to underwrite
Break	Loyalty opt-out; lost control; PR	Noisy household baskets; backlash; ethics

Distinctions

- **Legal in the United States at the time of the case** does not cancel an **ethical** and **relationship** problem.
- Loyalty consent for **analytics / coupons** is not the same, in customers' minds, as **selling to an insurer who raises premiums**.
- The customer is the **third party** whose data is traded while they are **not in the negotiation**.
- Purchase ≠ consumption; data has **noise**, but the pilot still found **real patterns**.
- This is not only a privacy case: it is **data as competitive strategy** (personalised product, exclusive rights).
- Free consumer apps that "do not charge" are in the same family: **data is the price**.

Exam lines

- ShopSense: loyalty + analytics + covert scanner sales; IFA wants grocery data to **personalise health premiums**.
- Legal in operating states then; **~$1B**; wellness spin; **trust, opt-out, loss of control** on the con side.
- Ethical core: **eating and drinking monitored by an insurer through a grocer**.
- Progressive = transparent personalised auto insurance; IFA path = same logic, weaker notice.
- Pilot correlation (trans fats ↔ claims) + exclusive data as **strategy**.
- Next session continues the case: trust survey, GDPR principles, RBV dependence, joint product.

Lecture T41: Information Privacy — Economics and Strategy — Part 03

Learning focus

- Use the **McKinsey 2019** confidence numbers to explain why retail trust is a **strategic** asset.
- Apply **purpose limitation, transparency, and data minimisation** to the ShopSense–IFA decision.
- Show why IFA's analytics strategy fails a strict **resource-based view** test (data not owned).
- Explain why **notice + old consent** is weak, and why a **joint product** is the smarter ethical design.

Key terms

Term	Meaning in this lecture
Purpose limitation	Use only for the disclosed collection purpose
Transparency	Customer say on external sharing; not selective disclosure
Data minimisation	Only necessary fields; deletable from one store
Selective disclosure	Organisations telling only convenient uses — drives low trust
RBV / VRIO	Strategy on valuable, rare, inimitable resources you **control**
Dependence / opportunism	Vendor can raise price or sell the same data to a rival
KBV	Insights/knowledge may be owned even if raw data is not; raw-material dependence remains
Joint product	Co-branded ShopSense–IFA insurance so sharing is visible in the offer
Attention problem	Notices exist; customers do not read them, so ethics are not fixed

Distinctions

- **Financial services look more trusted than retail** in McKinsey 2019; a grocer selling to an insurer is therefore **especially** dangerous for ShopSense.
- Disclosure as practised is often **selective**, which **is** the confidence problem.
- **Purpose limitation** forbids using coupon data to **set premiums**.
- **RBV fails** if the strategic resource is **rented**. KBV does not erase that dependence.
- The ethical scandal is not only misuse; it is that **the person is not in the deal**.
- **Legal consent + notices** already exist and **do not solve ethics**, because of **attention**.
- **Joint product** is offered as clearer than another T&C checkbox.

Exam lines

- ~10% retail data-handling confidence vs better healthcare/finance image.

- Three GDPR-style pointers: purpose, transparency, minimisation (and one-place deletion).
- Amazon: loyal customers charged **more**; sued; never throw data away.
- IFA strategy = differentiation on **un-owned** data → vendor opportunism.
- Customer absent from two-party trade = ethical core.
- Notices fail; **IFA–ShopSense insurance** as the design that puts the customer in the loop.
- Bridge to next class: **privacy as strategy** (Apple vs safety / Snowden).

Lecture T42: Privacy — Strategy and Safety — Part 01

Learning focus

- Recap why privacy is **individual, economic, and strategic**, then add **safety vs privacy**.
- Reconstruct **PRISM / Snowden** and the **Snowden effect** on Cisco, cloud, and "NSA-resistant" marketing.
- Walk Apple's encryption path: optional FDE → **default FDE (iOS 8)** → **iMessage E2E with no master key**.
- Compare **no encryption, E2E, key escrow, and split keys** as government-access designs.

Key terms

Term	Meaning in this lecture
Privacy vs safety	Capstone tension: E2E privacy vs national/victim justice
PRISM	NSA collection from firms, revealed 5 June 2013
MUSCULAR	NSA–UK joint collection
Snowden effect	Lost US tech sales, localisation, NSA-resistant marketing
FDE	Full disk encryption; default from iOS 8
Master key	What Apple claims **not** to have after passcode+device UID
CALEA	1994 US lawful intercept statute, later VoIP
Key escrow	Extra government-held key
Split keys / secret sharing	Several keys required in sequence

Distinctions

- Privacy is already **paradoxical and behavioural**; this case adds **state power** that does not play by the same law.
- Apple's stance looks **ideological** but must be read as **strategy** (developed in later parts).
- **Giving the US a special door** forces the same door for **repressive** states — or Apple becomes a **judge of countries**.
- **China audit** is already on the table as a **consistency** problem.

- Default encryption matters because **most people will never turn optional crypto on**, especially on slow Androids.
- "Apple cannot decrypt" is a **technical** claim that **shifts liability**, not only a slogan.

Exam lines

- Capstone: individual paradox + data trade ethics + **government as big brother**.
- Snowden/PRISM/MUSCULAR; hero vs traitor; industry **Snowden effect**.
- Cook's three dilemmas; Comey's unopenable safe; 6-digit passcode / 2FA / default crypto.
- iOS 8 default FDE; iMessage E2E; **no master key** (passcode + device-unique key).
- CALEA vs EU encryption policy; escrow vs split keys.
- Next: why governments want backdoors **now**, and Apple's **business model** versus Google's.

Lecture T43: Privacy — Strategy and Safety — Part 02

Learning focus

- Explain why default iOS 8 FDE changed **criminal investigation** (Manhattan DA: **74 of 92** phones dark).
- Separate **post-incident investigation** from **continuous government monitoring** (instructor's distinction).
- Compare **key-disclosure law**: US (no forced self-incrimination) vs UK/Australia vs **India IT Act s.69 (up to 7 years)**.
- Tie Apple's privacy **USP** to a business model that **does not sell ads**, and flag the **China data-centre** contradiction.

Key terms

Term	Meaning in this lecture
Default FDE effect	Lawful devices go dark (74 of 92)
Investigation vs monitoring	After a crime vs always-on collection/profiling
Five Eyes	US–UK–Canada–Australia–NZ SIGINT pact (1941)
TAO	NSA Tailored Access Operations
Key disclosure law	Whether you can be jailed for not decrypting
IT Act s.69	India: refuse to decrypt → up to 7 years (2008 amendment)
Escrow compromise	One stolen master key burns the whole corpus
Privacy USP	Marketing rating enabled by **not** living on ads
China audit	Local storage + alleged code review vs "no backdoor" claim

Frameworks / formulas

Jurisdiction	Can the state force the password?
US	No compelled self-incrimination; voluntary disclosure
UK, Australia	Yes, legally force key disclosure
India	s.69 IT Act: non-compliance up to **7 years**

Distinctions

- **74/92** is about **default** encryption, not about criminals being especially clever.
- **Safety after a death** is a serious argument; **Snowden-style bulk monitoring** is a **different** demand. Do not mix them.
- Government is **not God**; it is **partisan people**.
- A backdoor for "good" US agencies is a backdoor for **hostile regimes and hackers**.
- Apple "does not sell data" ≠ Apple "has no data." It has **cards and IDs**; it does not **monetise** them like Google.
- **China audit** undercuts a simple moral reading of the US encryption fight.

Exam lines

- iOS 8 default FDE: Manhattan **74 of 92** dark phones; Comey: unopenable evidence.
- Instructor split: **case investigation** vs **permanent monitoring**.
- US vs UK/Australia vs **India s.69 / 7 years**.
- Backdoor costs: dissidents, hackers, master-key leak, Greek parliament.
- Apple = devices revenue, privacy ratings; Google = ads; 400M iTunes records still held.
- China: in-country DC, audit, possible code share, Cook denial.
- Next: moral obligation, COVID apps, ATT, CSAM, San Bernardino.

Lecture T44: Privacy — Strategy and Safety — Part 03

Learning focus

- Use the **locker** metaphor to split **case-by-case opening** from a **permanent government key**.
- Compare **Apple–Google exposure notification** with **Aarogya Setu / StopCOVID** (location vs Bluetooth random IDs).
- Explain **ATT**, **CSAM neural hash**, and why Google's toddler-photo false alarm is the cautionary tale.
- Read Apple's privacy fights as **strategy**: San Bernardino, Israel crack, and **advertising share** versus Facebook/Google.

Key terms

Term	Meaning in this lecture
Locker metaphor	Customer holds the only key; Apple claims it cannot open
Case-by-case vs permanent	Fair opening of a dead user's device vs always-on spare key
Exposure notification	Bluetooth random IDs; no location; user-reported positive
StopCOVID / Aarogya Setu	State apps that wanted more location/control than Apple–Google
ATT	App Tracking Transparency — per-app tracking switch
CSAM	Child Sexual Abuse Material detection
Neural hash	Perceptual hash: same scene, same hash; unlike SHA-style file hash
Private set intersection	Match against CSAM DB without Apple learning non-matches
Threshold secret sharing	Do not decrypt/report until many hits; then humans review
San Bernardino	14 killed; Apple refused backdoor; FBI cracked via Israel

Frameworks / formulas

Move	Public story	Instructor's extra reading
Refuse FBI OS for one phone	Privacy principle	Also **protect the marketing position**
Exposure Notification	Privacy **and** health	Governments still wanted **location**
ATT	User transparency	**Shift digital ad share** to Apple
CSAM on-device hash	Middle ground	Threshold + humans vs Google's false positive

Distinctions

- **Culture and profit** explain Apple-in-China better than pure ethics.
- **Dead-user locker ≠ government spare key for every locker**. The case **mixes** them; unmix them.
- Aarogya Setu "open source" was **client only**; **server side closed** — that is the transparency gap.
- CSAM neural hash is **not** cryptographic file hashing; **on-device + threshold + manual review** is the privacy story; Google's toddler case is what you get **without** those brakes.
- San Bernardino: cooperate **for that case**; do **not** build a **permanent** door — and Apple still **lost face** when Israel cracked the phone.
- ATT is **privacy theatre and ad strategy at once**.
- Complete privacy would **end the ad industry**; that is a **hard reality**, not a slogan.

Exam lines

- Moral duty: culture + law of the land; Apple bends in China when profit is at risk.
- Locker: customer key; **fair** to open if the key died with the user; **unfair** permanent government key.
- Apple–Google: Bluetooth randoms, 14 days, no GPS/identity; France/India wanted more state control; fake reports; Aarogya Setu server not open.
- ATT → Facebook ~$10B; Apple also chasing **in-app ads**.
- CSAM: neural hash on device, NCMEC, PSI, threshold, manual review.
- San Bernardino 14 dead; Israel crack; encryption as **USP**; privacy vs safety remains an **open political** fight.

Lecture T45: Cyber Security and Privacy — Capstone Discussion A

Learning focus

- Stop treating **threat, attack, vulnerability, and risk** as synonyms; write **risk as residual risk**.
- Tune biometrics on the **FAR / FRR** trade-off; know why biometrics cannot be the only authenticator.
- Map blockchain **confidentiality, immutability, and non-repudiation** onto **encryption + hashing + private-key signature**.
- State the taught order for **ransomware**: **report** (DPDP / GDPR window), then restore operations (often **crypto** payment).

Key terms

Term	Meaning in this lecture
Threat	Source of risk
Attack	Point-in-time event
Vulnerability	Unplugged hole; what exploits target
Risk	State combining probability and impact; formula output is residual
Residual risk	Risk left after current measures
Loss frequency	f(P(threat), P(attack success))
Loss magnitude	From impact
FAR / FRR	False accept (false +) / false reject (false −)
Immutability	Hash as permanent transaction ID
Non-repudiation	Cannot deny you signed; private key / digital signature
Collision resistance	Hash property against two inputs, one digest (integrity)
DPDP reporting	Indian duty to report an incident in a set time

Distinctions

- **Risk ≠ threat ≠ attack ≠ vulnerability.** Risk is the **composite state**.
- **Always residual:** assessment does not re-count risk already covered by controls; that is why the extra “minus existing measures” term was **dropped**.

- Vulnerability is an **input to loss frequency**, not the whole of risk; **impact** still required.
- FAR and FRR **move opposite**; the meeting point still has **error** → biometrics **not sufficient alone**.
- Blockchain **security** here means **confidentiality from encryption**, not a vague "blockchain is safe."
- **Hash ≠ encryption.** Hash locks **integrity/immutability**; encryption locks **secrecy**; **private key** locks **who signed**.
- **Repudiation** is refusing the act; **non-repudiation** is a **system property**, not a moral hope.
- **Pay the ransomer only after reporting**; payment rail is often **crypto** because the thief chooses it.

Exam lines

- Threat sources risk; attack is an event; vulnerability is the hole; risk combines frequency, magnitude, uncertainty — **and is residual**.
- Banana peel / unpatched OS; TVA; P(success) depends on remaining holes.
- FAR up ⇔ FRR down; tune; never zero; not sole authentication.
- Blockchain: public-key confidentiality, hash immutability (and previous-hash links), private-key non-repudiation; collision resistance; skip algorithm trivia.
- Ransomware: **report under DPDP / GDPR (74h as taught)**, then pay if needed, often in cryptocurrency.
- Full DPDP–GDPR table comes in the privacy module / student discussions.

Lecture T46: Cyber Security and Privacy — Capstone Discussion B

Learning focus

- Define **insider** and **insider threat** (CISA and SEI) including **former staff** and **unwitting** harm.
- Separate **malicious, accidental, and negligent** insiders; list **motives** (money, grievance, ideology).
- Recognise **technical indicators** (odd hours, failed logins, exfiltration) and **controls** (SIEM, DLP, UEBA).
- Apply **routine activity, neutralization, and deterrence** theories to **policy violation**.
- Outline **NITF** programme building blocks: senior official, working group, policy, continuous training, programme office.

Key terms

Term	Meaning in this lecture
Insider	Has **or had** authorised access/knowledge of resources
Witting / unwitting	CISA: harm can be deliberate or not

Term	Meaning in this lecture
Malicious / accidental / negligent	Steal-or-destroy / careless / ignores policy
Compromised insider	Their **credentials** were taken (failed then successful login)
Exfiltration	Unauthorised data leaving the organisation
Routine activity	Offender + target + **no guardian**
Neutralization	Talking yourself into the violation
Deterrence	Benefit vs certainty/severity/speed of punishment
SIEM / DLP / UEBA	Correlate logs / block leaks / score behaviour
NITF	US model for an insider-threat **programme**, not a gadget

Exam lines

- Insider = authorised access **now or in the past**; threat = use of that access to harm, **on purpose or not**.
- Types: malicious, accidental, negligent. Motives: **money, grievance, ideology** (Verizon DBIR).
- Snowden (contractor, no behaviour monitoring); Tesla 2023 leavers and 75k HR rows — **joiners and leavers**.
- Watch 2 a.m. logins, priv-esc, USB dumps; detect with SIEM, DLP, UEBA.
- Theories: routine activity, neutralization (Sykes & Matza), deterrence.
- NITF: named official, cross-functional group, policy, **ongoing** awareness, office that updates rules.
- Culture + monitoring + tech together; one insider can still take the firm down.
